Administrator Manual

Vehicle Washing Management System (Vehicle Washing)

User and Role Management, Configuration, Bookings, Payments, Reports, Backups, Auditing, Maintenance, and Incident Resolution

Brayan Estiven Patiño Cabrera (Project Leader), Juan Camilo Guilombo Osorio (Frontend Leader), and Merari Urbano (Backend Leader)

Technologist in Software Analysis and Development (ADSO), Servicio Nacional de Aprendizaje (SENA), Training Center: Industria

Ficha 3145556

Instructor: Karol Daniela Correa

October 27, 2026

Manual Type: Administrator Manual (Business Administrators and IT Administrators) · Version 4.12

Version Control

Table 1 records the change history of this document. Each time an administrative function, an operating procedure, or the implementation status of a module changes, a row must be added with the version, the date, the description, and the person responsible.

Table 1

Version History of the Administrator Manual

Version	Date	Description of the change	Responsible
2.0	2026-10-06	Creation of the administrator manual (in Spanish) from the project documentation, within version 2.0 of the manual set.	Development team
3.0	2026-10-07	Translation into English, APA Style (7th ed.) formatting, and verification against the source code. The administration module of the web application is now documented screen by screen (it was described as nonexistent). Corrected: implementation status of each function, creation of accounts from the panel, absence of account lockout, manual operator assignment, payment review and manual payments, functions saved only in the browser (business data, roles, and promotions), real names of containers and database, and the state of the audit trail.	Development team
3.1	2026-10-09	Update against the code of October 9, 2026 (ADR-011 sections 9 to 12 and ADR-015), and creation of the Spanish version (Manual_administrador_LavadoVehicular_3145556_ES.md). Updated: implementation status table; permission matrix of the three fixed roles saved on the server (informative, not enforced); loyalty points per service; promotions as real percentage coupons unlocked with points; refunds from the interface with reversal of points; comparison of the declared amount; validation of reused references; customer notices of payment results; staff notifications for administrators; inspection report notified to the customer instead of WhatsApp; payment-service in Docker; new notification types and dead-letter checks.	Development team
4.0	2026-10-16	Review against the code of October 16, 2026. The figures changed from placeholders to real screenshots. Updated: account lockout after failed attempts, automatic operator assignment with the optional choice of the customer, business data and inspection reports saved on the server, consent to the legal documents stored at registration, automatic creation of the first administrator with ADMIN_EMAIL and ADMIN_PASSWORD, translated refund texts, new traces in Table 15, risks in Table 16, and Annex B items that were resolved.	Development team

Version	Date	Description of the change	Responsible
4.1	2026-10-17	Review against the code of October 17, 2026. Added the inspection report from the mobile app (section 12.5): it opens from the booking detail, takes the photos with the camera or the gallery, shrinks them on the phone before uploading them, and shares the link with the phone menu.	Development team
4.2	2026-10-19	The user type is changed from Management > Users (section 10.3); an administrator account cannot be deactivated (section 9.4).	Development team
4.3	2026-10-19	Screenshots taken again on October 19, 2026, with demo data, and new Figure 5 of the business data to be completed (section 11.1).	Development team
4.4	2026-10-20	The user type change from Management > Users was removed, since the team reverted it in the web, the app, and the server: the role is chosen when the account is created (section 10.3). The Registered filter was removed from the users list (section 9.2). Notifications open their detail with a button to go to Bookings or home (section 12.7).	Development team
4.5	2026-10-21	Review against the code and the server of October 21, 2026: deactivating an account makes its session stop working (sections 9.4, 9.6, and 17.5); the roles tab says that the role decides the access (section 10.1); the cash account and its option for the customer (section 11.4); bookings that close on their own, single count of bookings without an operator, and the assignment lock (sections 12.3 and 12.4); receipt of at most 2 MB (section 12.6); reports with only completed bookings (section 13); automatic backups of the public server (sections 14.6 and 15.2) and security headers (section 17.4). The date and the version of the cover and the row of data that used to be stored only in the browser (Table 12) were corrected.	Development team
4.6	2026-10-21	Change of the rule for bookings that end without being closed, reviewed by the team on the night of October 21: only a confirmed booking that never had an operator becomes No-show on its own; one that had an operator and nobody recorded goes to the **To close** card of the home screen (web and mobile app), where the administrator chooses **Attended** or **No-show** (sections 6.3, 8.3, 12.3, and 12.7). Bookings without an operator with a single rule in the mobile app too (sections 8.3 and 12.4); *FOLLOW_UP_** variables (section 11.6); new incident and glossary term (Tables 18 and 20).	Development team

Version	Date	Description of the change	Responsible
4.7	2026-10-23	Review against *develop* of October 23, 2026: manual backup with *backup-db.sh* and *verify-backup.sh* instead of a *BACKUP DATABASE* with *COMPRESSION*, which SQL Server Express does not support (14.3); the daily task is scheduled by *setup-server.sh* and reads the password from *.env.production* (14.4); start-up task of the continuous deployment, not yet tested (14.6); **To close** looks back 28 days (12.3); changing or recovering the password revokes sessions and removing a role cuts the token (9.4, 9.6, and 10.3); a coupon discount goes from 1 to 99 % (12.8); variables the compose file already passes (11.6); broken link in the table of contents (10.3) and reference to the mobile app (6.2). Includes the content of Merari Urbano's *fix/A-03*, *fix/A-04*, *fix/A-05*, *fix/E-02*, *fix/E-07*, and *fix/E-20* branches.	Development team
4.8	2026-10-24	Review against *develop* of October 24, 2026, which runs on the public server since that day: the permission matrix is read-only (6.3, 7.3, 10.1, and 17.5); the screens refresh on their own (4.1); request limit on sign-in and attempt cap on the recovery code (11.5 and 17.5); new variables (11.6); schedule or bay changes that clash with bookings (11.2 and 11.3); inactive cash in the counter payment (11.4 and 12.6); price greater than 0 (12.2); warning when changing the services of a booking with a payment, status changes that cancel the reminders, and a 4-hour window for the operator to record (12.3); notes visible to the operator (12.4); changed amount (*AMOUNT_CHANGED*), cancelled-booking notice, and unique reference (12.6); fixed discount in pesos (12.8); *:prev* images, *rollback.sh*, backup retention, and merged continuous deployment (14.6, 15.2, and 15.4); Annex B up to date.	Development team
4.9	2026-10-26	Payment at booking, reviewed against *develop* of October 26, 2026 and deployed to the public server that day: the payment method appears in the booking detail, digital bookings without a receipt are cancelled automatically with the reason *PAYMENT_TIMEOUT*, and the customer has at most one active cash booking (12.3); cash is recorded by the administrator, without a receipt (12.6); new variables (11.6).	Development team
4.10	2026-10-26	The server boot task is explained with *v1.1.0* already published on October 26, 2026 (14.6).	Development team
4.11	2026-10-26	Continuous deployment is active since October 26, 2026 (14.6).	Development team
4.12	2026-10-27	At most 10 services per booking and alternatives that respect the other bookings of the vehicle (booking management).	Development team

Note. Dates are written in the ISO 8601 format (year-month-day). Prepared by the development team.

Table of Contents

Version Control 2
4. Introduction 8
4.1 Sources and State of the Documentation 8
5. Objective 9
5.1 General Objective 9
5.2 Specific Objectives 9
6. Scope 9
6.1 What This Manual Covers 9
6.2 What This Manual Does Not Cover 10
6.3 Implementation Status of the Administrative Functions 10
7. Administrator Profile 12
7.1 Who the Administrator Is 12
7.2 Responsibilities 12
7.3 Permissions and Restrictions 13
7.4 Fundamental Rule: Individual Accounts 13
8. Access to the Administration Panel 14
8.1 Access Requirements 14
8.2 Logging in to the Panel 14
8.3 General Control Panel 15
8.4 First Administrator Account 17
9. User Management 18
9.1 Account Management Principles 19
9.2 Consulting Users 19
9.3 Creating an Operator or Administrator Account 20
9.4 Activating and Deactivating an Account 22
9.5 Password Reset 22
9.6 Active Sessions 23
10. Role and Permission Management 24
10.1 The Three Fixed Roles 24
10.2 Control by Role and by Ownership 25
10.3 A Person's Role 25
11. System Configuration 25
11.1 Business Data 25

11.2 Opening Hours and Exceptions 27
11.3 Washing Bays 29
11.4 Payment Methods and QR Codes 30
11.5 Platform Security Parameters 32
11.6 Operating Environment Variables 33
12. Management of Core Information 34
12.1 Operators and Availability 34
12.2 Services, Prices, and Points 35
12.3 Bookings 36
12.4 Assigning an Operator 40
12.5 Vehicle Inspection Report 42
12.6 Payment Review and Approval 44
12.7 Notifications and Announcements 47
12.8 Promotions and Loyalty 48
13. Administrative Reports 49
13.1 Support Queries 51
14. Backups 52
14.1 What Must Be Backed Up 53
14.2 Recommended Policy 54
14.3 Generating a Manual Backup 54
14.4 Automating the Daily Backup 55
14.5 Backup Before Changes 56
14.6 Automatic Backups of the Public Server 56
15. Data Restoration 57
15.1 When to Restore 58
15.2 Full Restoration Procedure 58
15.3 Post-Restoration Verification 59
15.4 Rolling Back a Migration 60
16. Auditing and Action History 61
16.1 What the System Records 61
16.2 Audit Queries 62
16.3 Periodic Review and Retention 63
17. Security Recommendations 64
17.1 Accounts and Passwords 64

17.2 Personal Data 64
17.3 Secrets and Configuration 64
17.4 Network and Exposure 65
17.5 Accepted Risks the Administrator Must Know 66
17.6 Preventive Maintenance 66
17.7 Incident Resolution 68
17.8 Severity Levels and Escalation 70
18. Glossary 70
References 72
19. Annexes 73
Annex A. Source of the Screenshots 74
Annex B. Information to Confirm Before Delivery 75
Annex C. Incident Record Template 76
Annex D. Delivery Checklist 77

Note. Numbering starts at 4 because sections 1 to 3 are the cover, the version control, and the table of contents, which have no number in their title. It is kept this way so that the cross-references between documents by section number (for example, "Installation Manual, section 10") remain valid.

4. Introduction

The Vehicle Washing Management System (Vehicle Washing) manages the bookings, the assignment of operators, the execution of services, and the verification of payments of a vehicle washing business. Within the system, the administrator is the person who runs the business day to day and who is also responsible for the security of the accounts, the integrity of the data, and the continuity of the service.

This manual is addressed to business administrators and information technology (IT) administrators. It explains how to access the administration panel; manage users and roles; configure the business, the opening hours, the washing bays, and the payment methods; manage operators, services, bookings, inspections, and payments; consult reports; and, from the infrastructure point of view, make backups and restorations, consult the available traces, apply a preventive maintenance plan, and resolve incidents. The security controls are aligned with the risk management practices of the National Institute of Standards and Technology (Joint Task Force, 2020), the contingency principles of the NIST SP 800-34 guide (Swanson et al., 2010), and the OWASP Top 10 (OWASP Foundation, 2021).

4.1 Sources and State of the Documentation

The manual was verified against the source code of the web application and of the services (Vehicle Washing Development Team, 2026b, 2026c, 2026d) and against the project documentation updated on October 21, 2026 (Vehicle Washing Development Team, 2026a). The web application includes a complete administration module under the route */admin*, restricted to the ADMIN role. The names of the screens, buttons, and messages are written exactly as they appear when the interface language is English.

Almost every screen of the module saves its data on the server. The exceptions are the reports, which are calculated in the browser from the bookings and payments, and the permission matrix, which is informative and, since October 24, 2026, read-only. Since that day the screens refresh on their own: on entering, on returning to the tab, with each new notification, and, on those that wait for another person (for example, **Payments** and **Bookings**), every 45 seconds while the tab

is visible; reloading the page is no longer needed to see a new payment or a status change. Section 6.3 states the status of each function so that the administrator knows which data are official. When the documentation does not define a value (for example, a retention policy or a recovery objective), the manual presents it as a **recommendation** and lists it in Annex B so that the team approves it, as the guide for writing manuals requires (Servicio Nacional de Aprendizaje [SENA], 2026).

5. Objective

5.1 General Objective

To guide the administrator in the management, configuration, and supervision of the Vehicle Washing Management System, ensuring a secure and orderly use of the platform, the protection of its data, and the continuity of its operation.

5.2 Specific Objectives

- Describe the profile, responsibilities, and restrictions of the business administrator and the IT administrator.
- Explain the management of accounts, the three fixed roles, and the access controls by role and by ownership of the resource.
- Detail the configuration of the opening hours, the bays, and the payment methods, and the management of operators, services, bookings, inspections, and payments.
- Present the reports of the panel and the support queries for the IT administrator.
- Establish verifiable procedures for backup, restoration, and consultation of traces.
- Provide a preventive maintenance plan and an incident resolution guide.

6. Scope

6.1 What This Manual Covers

- The functions of the ADMIN role in the web application (route */admin*): control panel, bookings, payments, management of users, roles, services, and promotions, hours and bays, operators, reports, notifications, profile, and settings.
- The procedures of the IT administrator on the SQL Server database, RabbitMQ, the Docker containers, and the logs: backups, restoration, traces, maintenance, and incident

resolution.

6.2 What This Manual Does Not Cover

- The use of the system by customers and operators (User Manual).
- The internal architecture, the complete data model, and the API contracts (Technical Manual).
- The initial installation of the environment (Installation Manual).
- The administration screens of the Android application, which offers modules equivalent to those of the web and is downloaded from the home page: they follow the same rules of this manual and their walkthrough is summarized in the User Manual, section 10.3.6.
- Staging and production environments, which the documentation declares outside the academic scope; the recommendations of this manual for those environments are indicative.

6.3 Implementation Status of the Administrative Functions

Table 2 summarizes the real status of each function in the version of October 21, 2026, reviewed against the code and with the system running.

Table 2

Implementation Status of the Administrative Functions

Function	Screen	Status	Section
Control panel with indicators	Dashboard	Complete (data from the server).	8.3
Create accounts and activate or deactivate them	Management > Users	Complete.	9
Roles and permissions	Management > Roles	Complete: the server applies the three fixed roles (ADR-015). The permission matrix is informative and, since October 24, 2026, read-only: it shows the permissions of each role, but it is not edited, because the role in the token decides the access.	10
Services, prices, durations by vehicle type, and loyalty points	Management > Services	Complete.	12.2

Function	Screen	Status	Section
Promotions and coupons	Management > Promotions	Complete: percentage coupons saved in payment-service, unlocked with points and applied when the customer pays.	12.8
Weekly hours, exceptions, and bays	Hours & Bays	Complete.	11.2 and 11.3
Business data	Settings > Business data	Complete: saved in booking-service, and they are the data customers see on the home page and in the help center.	11.1
Payment methods (accounts and QR codes)	Settings > Payment methods	Complete.	11.4
Operators, weekly availability, and absences	Operators	Complete.	12.1
Bookings: create, reschedule, change status, and cancel	Bookings	Complete.	12.3
Bookings to close (services that ended without being recorded)	Dashboard (web and mobile app)	Complete since October 21, 2026: **Attended** or **No-show**.	12.3
Operator assignment	Bookings, Dashboard	Complete: the system assigns a free operator when the booking is confirmed (the one chosen by the customer, if still free), and the administrator changes it by hand or assigns the bookings left without an operator.	12.4
Vehicle inspection report	Bookings > Inspection	Complete: the report and photos are saved in operations-service, and the customer receives the summary with the link to the report by notification and email (**Notify customer**).	12.5
Payment review, approval, rejection, and refund; manual payments	Payments	Complete.	12.6
Reports and export to Excel or PDF	Reports	Complete (calculated in the browser from bookings and payments; only completed bookings count).	13
Inbox of notifications, including staff notices	Notifications	Complete. Free announcements to users are sent only through the API.	12.7

Function	Screen	Status	Section
Loyalty points	Management > Services and Dashboard of the customer	Complete: credited when a payment is approved and reversed when it is refunded.	12.8
Backups, restoration, and traces	—	Not application functions: they are performed on the database and the infrastructure. On the public server backups are automatic since October 21, 2026.	14 to 16

Note. Prepared by the authors from the source code of the web application and the services, and from the technical backlog of the project (Vehicle Washing Development Team, 2026a).

7. Administrator Profile

7.1 Who the Administrator Is

The system defines three fixed roles: Administrator (code ADMIN), Operator (OPERATOR), and Customer (CLIENT). The administrator is the owner or manager of the business. This manual distinguishes two profiles that, depending on the size of the team, may fall on the same person (Table 3).

Table 3

Administration Profiles

Profile	Description	Sections
Business administrator (ADMIN role)	Runs the business through the administration panel of the web application.	8 to 13
IT administrator	Responsible for the servers, containers, database, backups, traces, and security. It is not an application role: it acts with infrastructure accounts.	14 to 17 and the database procedures of other sections

Note. There is no superadministrator role: the three roles are fixed and custom roles do not exist (ADR-010 and ADR-015).

7.2 Responsibilities

- Keep up to date the opening hours, the bays, the services, the prices, and the payment accounts.

- Check the **Bookings without an operator** block and assign by hand the bookings the system could not assign because no operator was free.
- Verify digital payments against the receipt and the bank, and record cash payments.
- Create, deactivate, and supervise the operator and administrator accounts.
- Consult the reports and the traces, and detect anomalous behavior.
- Ensure backups, restoration capability, and preventive maintenance.
- Handle incidents and document them.

7.3 Permissions and Restrictions

Table 4

Permissions and Restrictions of the Administrator

Permission	Restriction
Manages bookings, operators, hours, bays, services, prices, and payment accounts.	Works only through the panel with an individual account; direct access to the database belongs to the IT administrator.
Reviews, approves, or rejects payments and records manual payments.	A booking admits a single approved payment; a payment in review cannot be duplicated.
Sees the customer, vehicle, and booking information needed to operate.	Must treat it according to Law 1581 of 2012 and the security policy.
Creates accounts with their user type and activates or deactivates them.	Accounts are deactivated, not deleted; the user type is not changed after the account is created; an administrator account is not deactivated and nobody deactivates their own.
Consults the roles and the permissions of each one.	Cannot create or delete roles or edit the permission matrix, which is read-only.

Note. All the routes under */admin* require the ADMIN role; a person with another role who tries to open them is returned to the home screen of their own role.

7.4 Fundamental Rule: Individual Accounts

Each person who administers the system must use an individual and secure account. Administrator accounts must not be shared, because the session records and the fields that store who approved a payment identify the account that acted; a shared account makes it impossible to assign

responsibility. The account of any person who stops being part of the process must be deactivated immediately.

8. Access to the Administration Panel

8.1 Access Requirements

- Updated browser (Chrome, Firefox, or Edge) and connection to the system.
- An active account with the ADMIN role.
- For IT tasks: access to the machine where the containers run and to SQL Server with an infrastructure account.

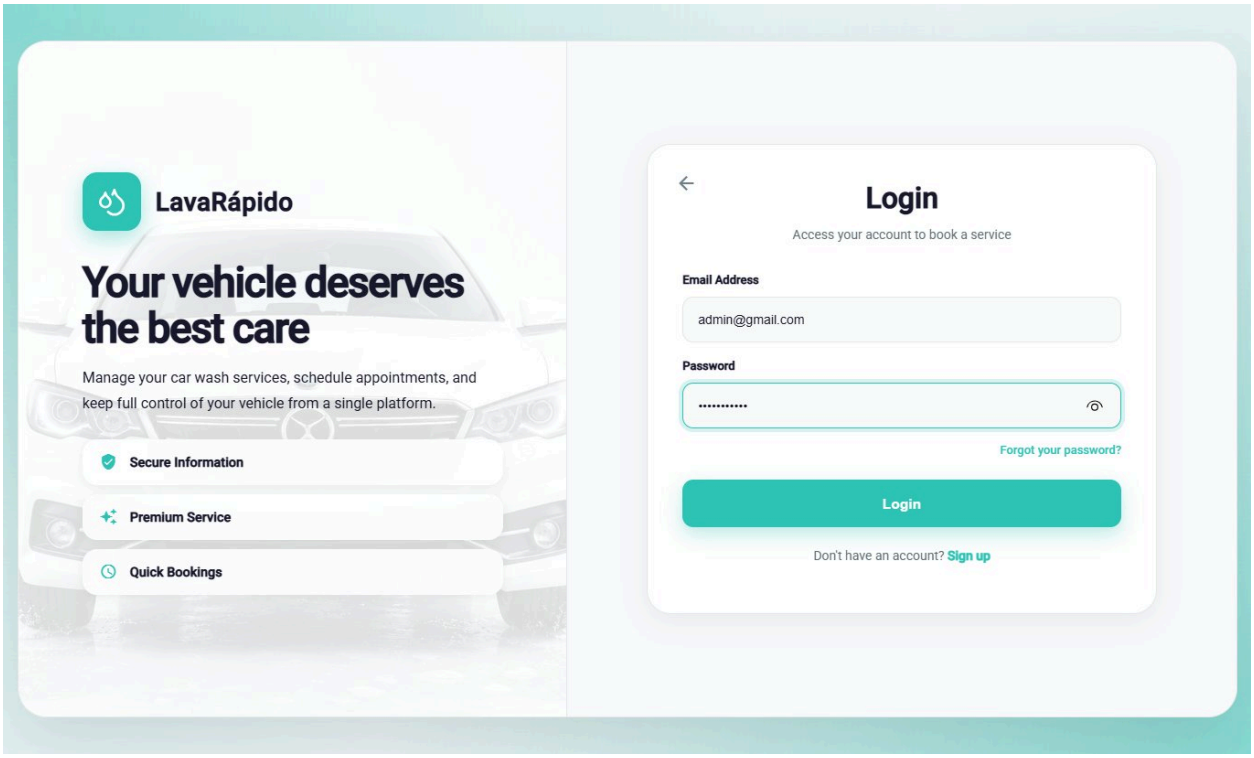
8.2 Logging in to the Panel

1. Open the web address of the application (in the local environment, *http://localhost:4200*).
2. Click **Login**.
3. Type the email address (ending in @gmail.com) and the password of the administrator account.
4. Click **Login**. The system validates the credentials and opens the administration panel (route */admin*).

The session lasts one hour; when it expires, the administrator must log in again. After five failed attempts within 15 minutes, the account is locked for 15 minutes; resetting the password unlocks it right away. Even so, administrator passwords must be long and unique (section 17.1).

Figure 1

Administrator Login



8.3 General Control Panel

The control panel (route */admin*, menu option **Dashboard**) summarizes what the administrator needs to run the day (Table 5).

Table 5

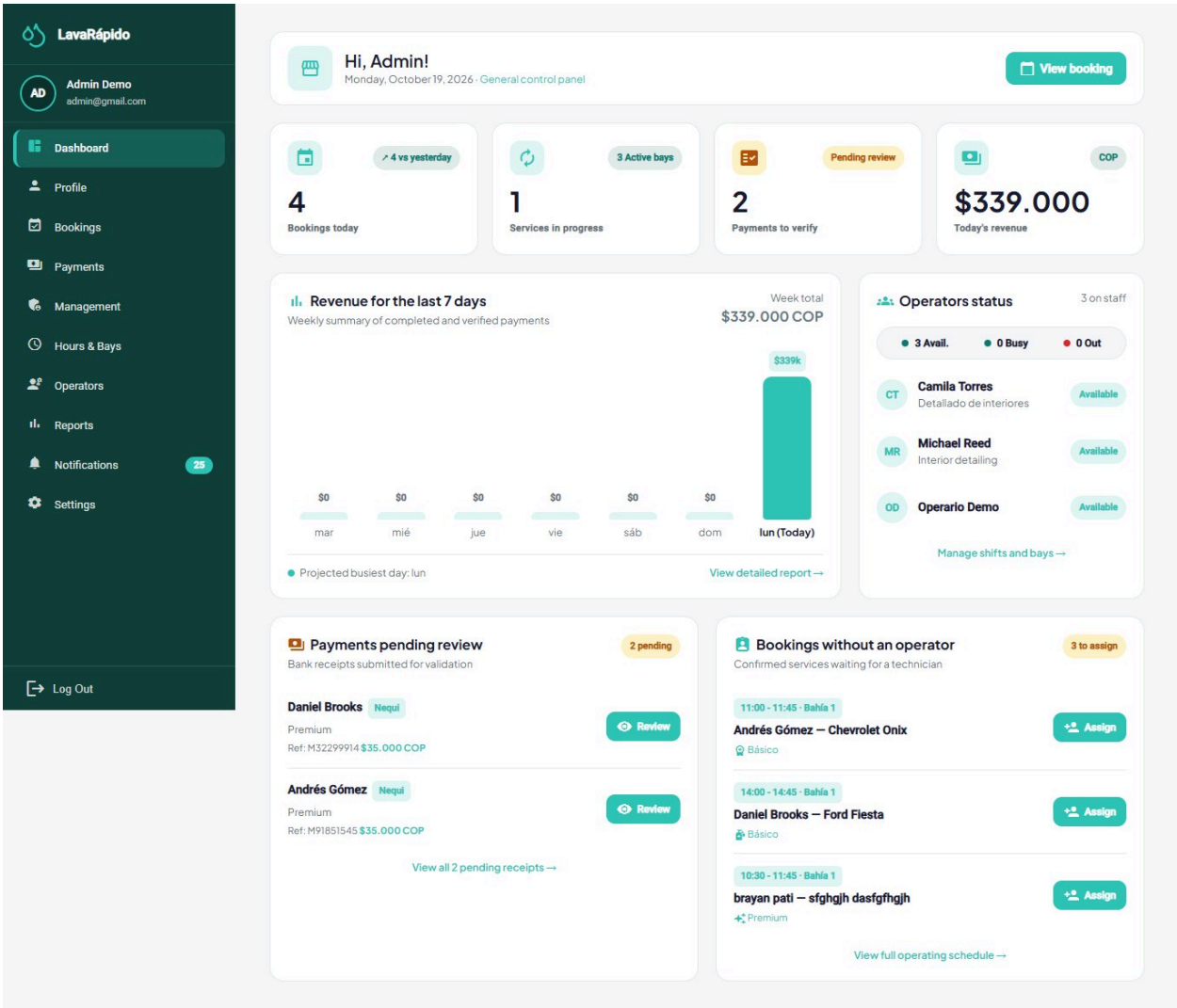
Elements of the Administrator Control Panel

Element	Information it shows	Administrator action
Bookings today	Number of bookings of the day, compared with the previous day.	Review the workload; **View today's bookings**.
Services in progress	Services that operators started and have not finished.	Check the progress.
Active bays	Bays available to receive bookings.	Verify the capacity of the day.
Payments to verify	Payments pending review.	Open the review (section 12.6).
Today's revenue	Total of the payments approved in the day.	Compare with the reports.
Revenue for the last 7 days	Chart with the week total and the projected busiest day.	**View detailed report**.
Operators status	Available, busy, and absent operators.	**Manage shifts and bays**.
Payments pending review	Last receipts submitted for validation.	**Review** each one.
Bookings without an operator	Scheduled or confirmed bookings waiting for a technician whose time has not ended; since October 21, 2026 it is the same count as the Bookings screen, on the web and in the mobile app.	**Assign** (section 12.4).
To close	Bookings with an operator that ended and nobody recorded (not started or not finished). It only appears when there is at least one, on the web and in the mobile app.	**Attended** or **No-show** (section 12.3).

Note. The names correspond to the panel when the interface is in English.

Figure 2

General Control Panel



8.4 First Administrator Account

The initial data loads the three roles but no user accounts. When the security service runs with the development profile (*dev*), it creates one demonstration account per role (administrator, operator, and customer); their credentials appear in the team guide of the infrastructure repository and must never be used outside a local machine.

In any other environment, such as the public server, the first administrator account is created by security-service when it starts (*AdministratorBootstrapRunner*). The IT administrator writes *ADMIN_EMAIL* and *ADMIN_PASSWORD* (and, optionally, *ADMIN_FIRST_NAME* and

ADMIN_LAST_NAME) in the *.env.production* file of the server and restarts the service. If there is still no account with the ADMIN role, the service creates it with the same rules as any account (password policy, unique email and document), and the log shows *First administrator created*. If an administrator already exists, the variables are ignored and can be removed from the file. The password is typed directly on the server and is never stored in a repository.

A new administrator is normally created from **Management > Users > Create user** with the Administrator role (section 9.3). The web and the app do not allow changing the user type of an existing account (section 10.3); if an account that already exists (for example, one registered from the public screen) must become an administrator, the IT administrator assigns the role with SQL, because the password was already generated by the application:

1. Check that the person already has an account (if not, the person registers from the public screen).
2. Look up the identifiers of the account and of the ADMIN role.
3. Insert the ADMIN role for the account in *security.user_role*.
4. Ask the person to log out and log in again; the system must open the panel */admin*.
5. Record the change (date, author, and reason) in the change log of the team.

```
-- Required identifiers
SELECT user_id, username FROM security.app_user WHERE username = N'<EMAIL>';
SELECT role_id, code FROM security.[role];

-- Assign the ADMIN role
INSERT INTO security.user_role (user_id, role_id)
VALUES (<USER_ID>, <ADMIN_ROLE_ID>);
```

An account can have several roles; when it has ADMIN, the web application opens the administration panel. Once the first administrator exists, the other administrators and operators are created from **Management > Users** (section 9.3), not with SQL.

9. User Management

A system account consists of a person (*security.person*: ID number, first names, last names, phone, and email) and an access account (*security.app_user*: username, password hash, active status,

and date of last login). The roles are assigned in *security.user_role*. The password is stored only as a BCrypt hash: no administrator can see or recover it (OWASP Foundation, 2021).

9.1 Account Management Principles

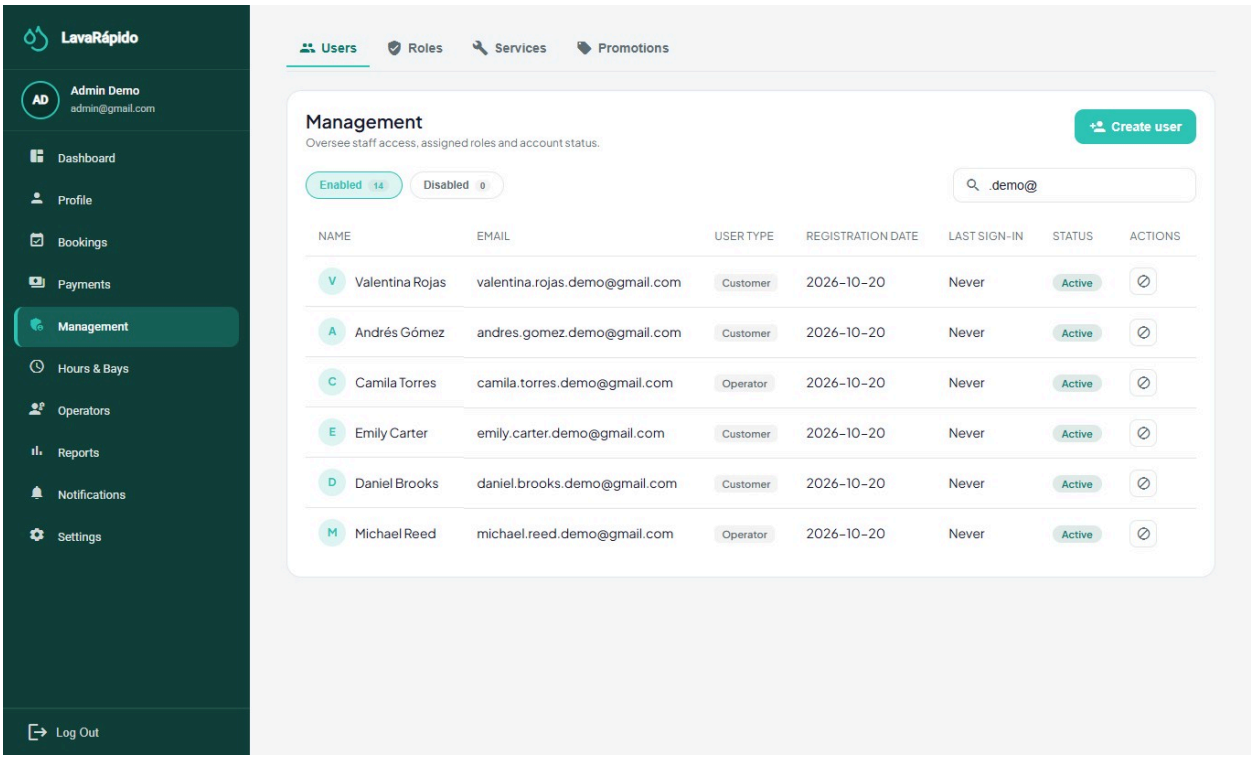
- **Accounts are deactivated, not deleted.** A deactivated account cannot log in, but its bookings, payments, and ratings are kept.
- **One email and one ID number per account.** The email (ending in @gmail.com) is the login username.
- **Least privilege.** Only the necessary role is assigned, and the account is deactivated when it is no longer needed.

9.2 Consulting Users

1. In the side menu, click **Management** and open the **Users** tab (route */admin/management*).
2. Review the table with **Name**, **Email**, **User type**, **Registration date**, **Last sign-in**, and **Status**. The user type is only shown; it is not changed from the table (section 10.3).
3. Use the **Enabled** and **Disabled** filters and the search box (name, email, or user type) to find an account. If the search finds nothing, **Clear filters** shows the enabled accounts again.

Figure 3

User List



9.3 Creating an Operator or Administrator Account

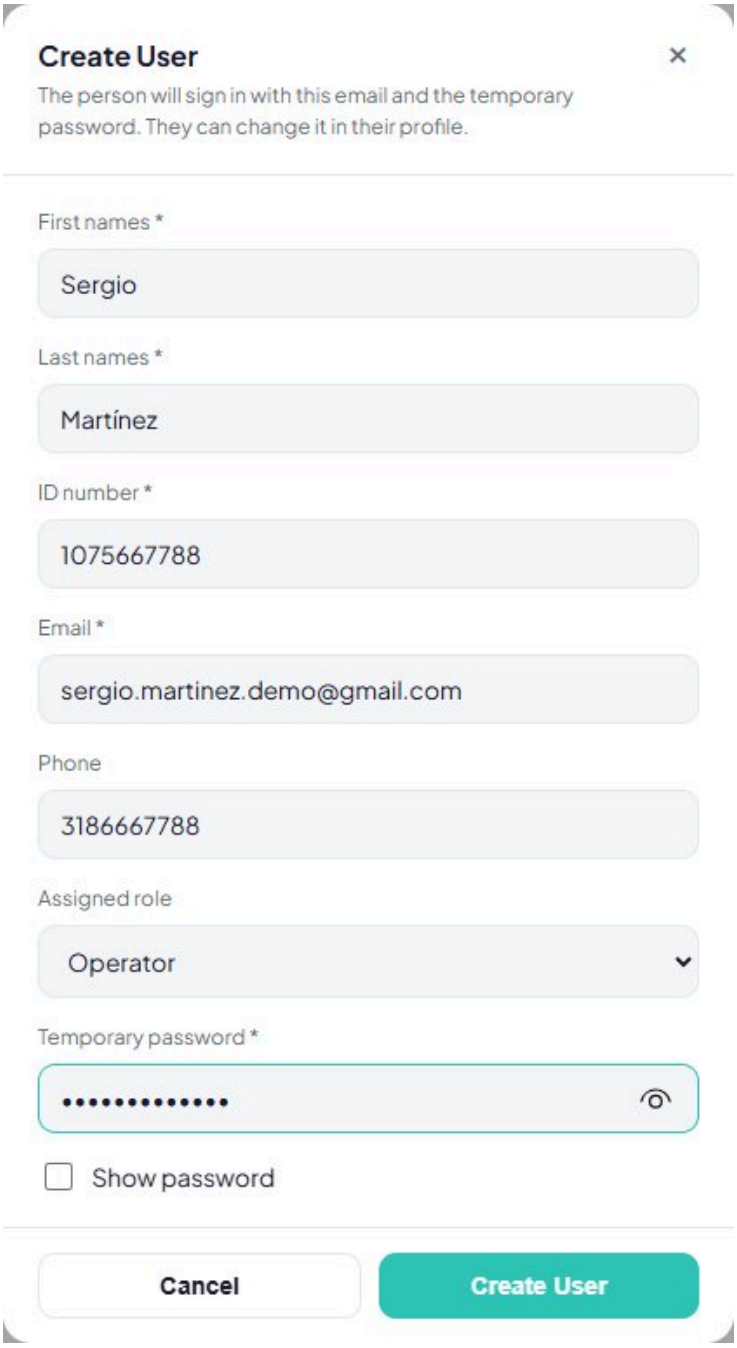
1. In **Management > Users**, click **Create user**.
2. Fill in the **ID number**, **First names**, **Last names**, **Email**, and **Phone** (optional).
3. Type a temporary password that meets the policy (minimum 8 characters, one uppercase letter, one number, and one special character); **Show password** lets you check it before saving.
4. Choose the **Assigned role**: Operator, Administrator, or Customer.
5. Click **Create User** and verify that the message "User created" appears and that the account is listed.
6. Deliver the temporary password through a private channel and ask the person to change it in **Profile** at the first login.

Operators can also be created from **Operators > New operator** (section 12.1), which creates the account with the OPERATOR role. The system never sends the password by email: the welcome

message of an account opened by an administrator explains that the password is requested from the administrator or recovered with "Forgot your password?".

Figure 4

Create User Window



9.4 Activating and Deactivating an Account

1. Locate the account in **Management > Users**.
2. Choose **Disable account** (or **Enable account** to reactivate it).
3. Confirm the message "Deactivate [name]? They will no longer be able to log in." Since October 21, 2026, if the person had an open session, that session stops working within 30 seconds on all their devices.
4. Verify that the status changes to **Disabled** and, if the person is an operator with pending services, reassign them (section 12.4).

An administrator account cannot be deactivated: the button appears blocked with the message "An administrator account cannot be disabled." Since the user type is not changed from the panel (section 10.3), removing an administrator requires the IT administrator to take that role away in the database (*security.user_role*) and write it down in the team's log. Since *develop* of October 23, 2026 (E-02, version 1.1.0), as soon as the role disappears from *security.user_role* the system revokes all of that person's sessions (*security.user_session.revoked_at*): the token that still said Administrator stops working within 30 seconds and, when signing in again, the person only has the roles left. Nobody can deactivate their own account either, from this table or from **Profile**.

9.5 Password Reset

The administrator cannot see or set a user's password. To regain access, the person uses **Forgot your password?**: a six-digit code arrives at the email, valid for 15 minutes, for a single use, and burned after five failed attempts (Table 6).

Table 6

Access Situations and Administrator Action

Situation	Cause	Action
The person forgot the password	—	Direct the person to password recovery; verify that the email is correct.
"Your account is disabled"	The account was deactivated.	Reactivate it if appropriate (section 9.4).
The code does not arrive	Wrong email, MAIL_ENABLED set to false, or an SMTP failure.	Check the registered email and the mail configuration (section 17.7).
The person changed the email	Change made from Profile with the current password.	The new email is the login username.

9.6 Active Sessions

Each login is recorded in *security.user_session* (start, expiry, revocation, IP address, and browser agent). Logging out marks the session as revoked, and deactivating the account revokes all its sessions. Changing the password from **Profile** revokes the person's other sessions (the one on the device where it was changed stays open) and recovering it with the code sent by email revokes all of them. Since October 21, 2026 the token of a revoked session stops working: security-service rejects it and the API Gateway cuts it before it reaches the other services, with a margin of up to 30 seconds (if security-service does not answer within 3 seconds, the gateway lets the request through and the token works until it expires). Nonconformity SEC-01 remains open: if a request carries the header with *bearer* in lowercase, the gateway does not check the session and the services other than security-service accept the token until it expires (Corrective Actions document). When a compromise is suspected, deactivate the account, change the JWT secret if the compromise affects the platform, and review the sessions:

```
SELECT TOP (50) s.user_session_id, u.username, s.started_at, s.expires_at,
       s.revoked_at, s.ip_address, s.user_agent
FROM security.user_session s
JOIN security.app_user u ON u.user_id = s.user_id
ORDER BY s.started_at DESC;
```

10. Role and Permission Management

10.1 The Three Fixed Roles

The server applies only the three fixed roles ADMIN, OPERATOR, and CLIENT (Table 7). The **Management > Roles** tab lists the three roles with their permissions and the number of users of each one. **The matrix is informative and read-only** (since October 24, 2026): it shows the permissions of each role stored in *security.role_permission* (*GET /api/v1/admin/roles-permissions*), but it no longer has the dialog to check or uncheck them. Real authorization depends on the role of the token (ADR-015), so changing the matrix would not grant or remove access; the tab explains it on screen.

Table 7

Matrix of Roles and Main Capabilities

Capability	ADMIN	OPERATOR	CLIENT
Register and manage vehicles	Look up by plate	—	Yes (own)
Create and cancel bookings	Yes (for any customer)	—	Yes (own)
Reschedule bookings and change their status	Yes	—	—
Assign or change the operator	Yes	—	—
Start and finish a service	—	Only those assigned to them	—
Pay and upload receipts	—	—	Yes (own)
Approve or reject payments; record manual payments	Yes	—	—
Rate a completed service	—	—	Yes, once
Configure hours, bays, services, and payment accounts	Yes	—	—
Create and deactivate accounts	Yes	—	Only deactivate their own
Consult reports	Yes	Their ratings	—

Note. Prepared by the authors from the endpoints of each service and their required roles.

10.2 Control by Role and by Ownership

A valid role is not enough: each service also verifies the ownership of the resource. An operator cannot start or finish a service assigned to another operator, and a customer only reaches their own bookings, vehicles, and payments. Each service validates the token and the role required by each route; the gateway routes the requests and does not check the token signature (ADR-006), but since October 21, 2026 it cuts the tokens of closed sessions. A request from one role to a resource of another returns error 403.

10.3 A Person's Role

Each account has one user type (Client, Operator, or Administrator), chosen when it is created: Client when the person signs up from the public screen, or the **Assigned role** of **Create user** (section 9.3) when the administrator creates it. Since October 20, 2026, the web and the app do not offer changing the user type of an existing account: the **User type** column of **Management > Users** only shows it, and the server has no route to change it.

If a person really needs another role, the IT administrator adjusts it in the database (*security.user_role*, with the same procedure as section 8.4) and records who asked for the change and why in the team's log. If a role was removed, since *develop* of October 23, 2026 (E-02) there is no need to ask the person to sign out: the system compares the token's roles with *security.user_role* and revokes all their sessions within 30 seconds. If a role was only added, the person must sign out and sign in again so the token includes it. If the new role is Operator, the operations service creates their operator record the next time the operators are listed; then give them shifts in **Operators** (section 12).

11. System Configuration

11.1 Business Data

Settings > Business data (route */admin/settings*) gathers the data of the business in four cards: **General information** (legal name, trade name, tax ID, business type, founding date, and legal representative), **Location & contact** (address, phones, and email), **Tax information** (tax regime, CIIU activity, DIAN resolution, invoice prefix, and range), and **Official channels** (website,

social networks, support line, and service hours). These data are saved in booking-service (*GET* and *PUT /api/v1/admin/establishment*), which validates each field before saving it. They are the same data customers see on the home page, in the footer, and in the help center, so a change reaches every user when the page is reloaded. The accounts and QR codes for receiving payments are configured separately, in **Payment methods** (section 11.4).

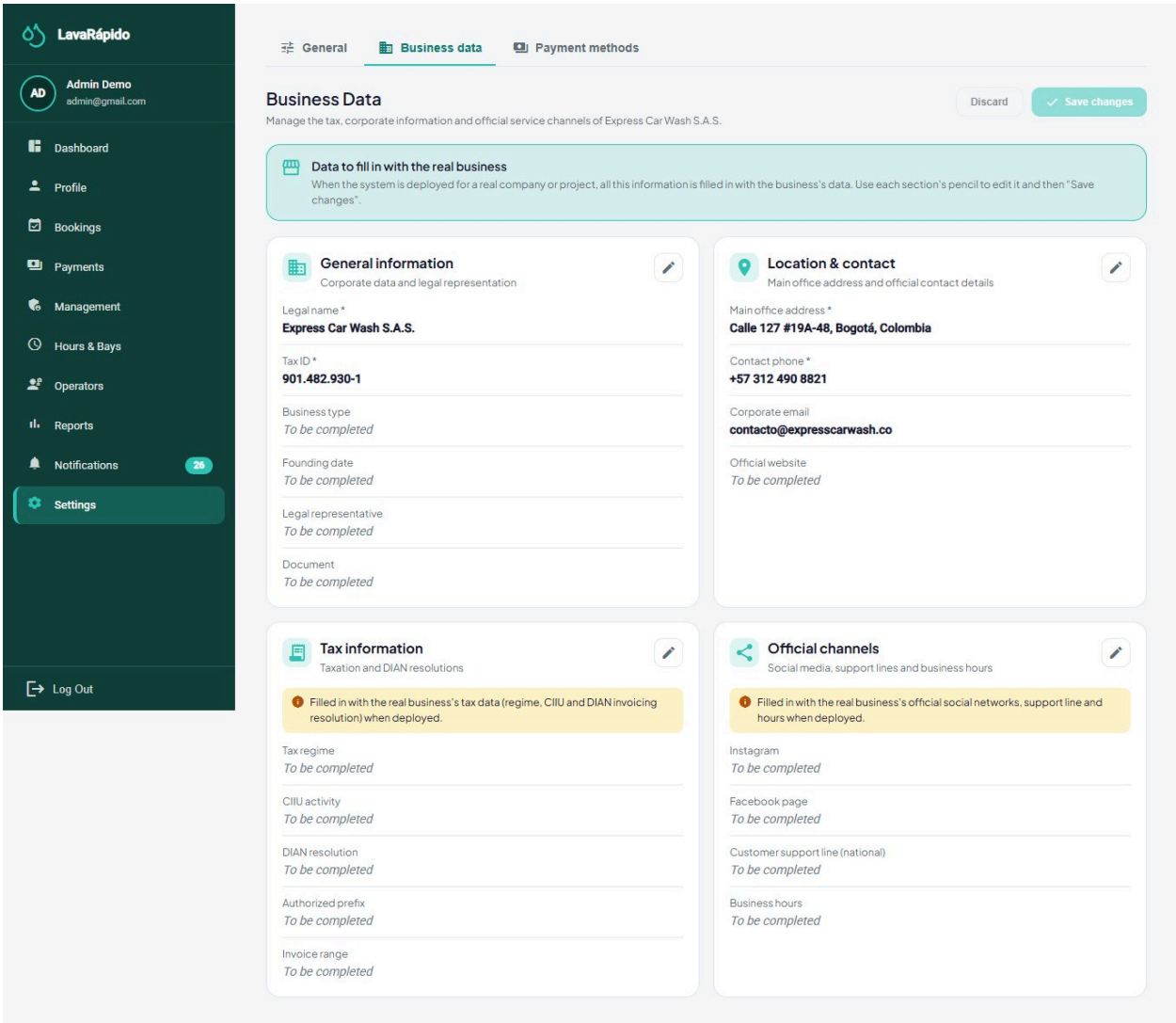
The system is delivered without the data of a real business: missing fields show **To be completed**, and a notice at the top of the screen reminds the administrator to fill them in when the system is implemented for a company.

1. Click the pencil of the card to change.
2. Fill in the fields in the window and click **Apply**. The screen shows **Unsaved changes**.
3. Repeat with the other cards if needed and click **Save changes** ("Data saved"). **Discard** undoes what has not been saved.

The legal name, the tax ID, and the address are required; the phone must have at least 7 digits, the email must be valid, and the founding date cannot be in the future. In the mobile app, **More > Settings > Business data** shows the same cards with their pencil and saves to the same place.

Figure 5

Business Data to Be Completed



11.2 Opening Hours and Exceptions

The **Hours & Bays** screen (route */admin/schedule*) has two tabs: **Business hours** and **Wash bays**. The changes of this screen affect the availability offered to customers immediately.

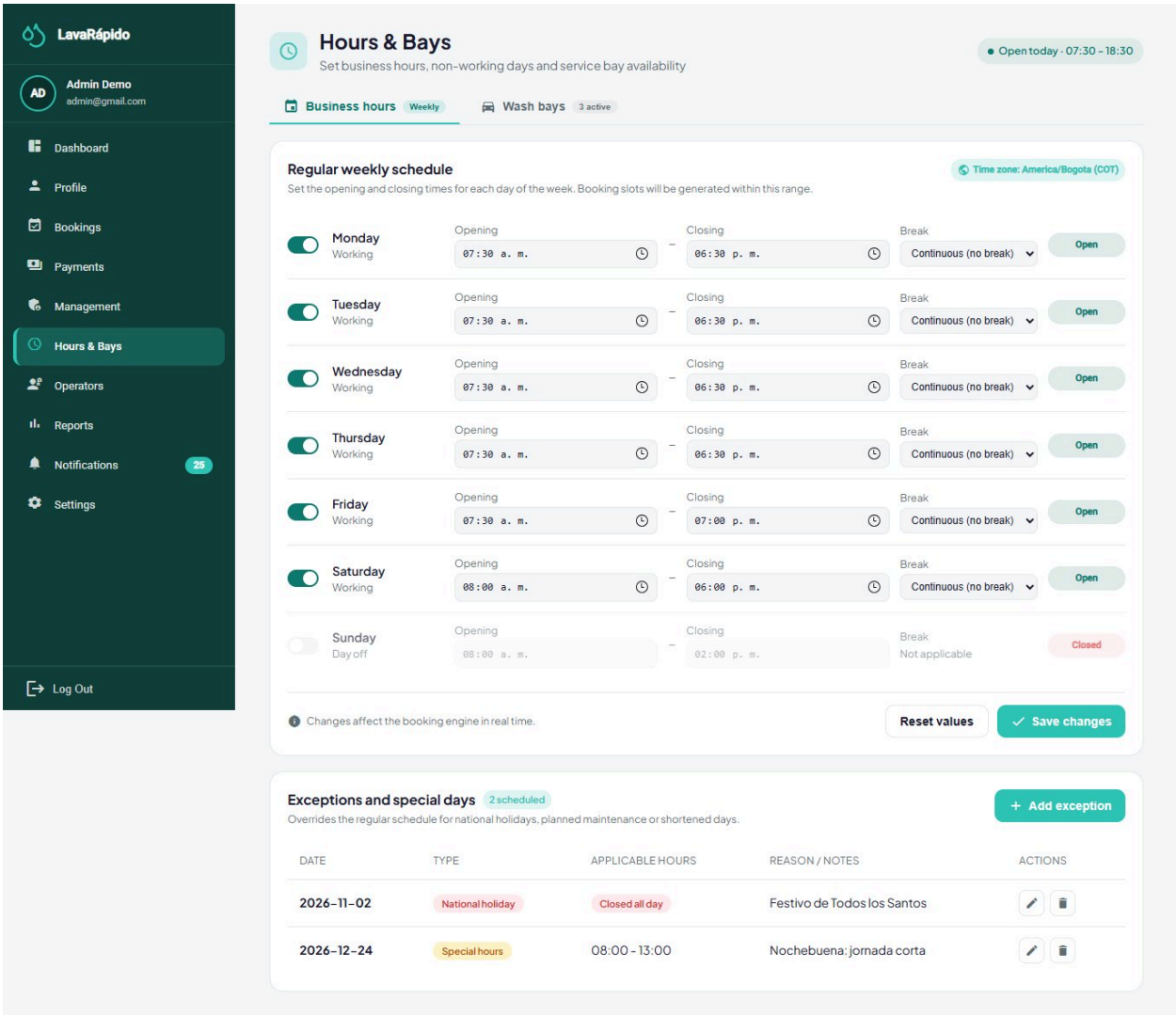
1. In **Business hours**, review the **Regular weekly schedule**: for each day, **Open** or **Closed**, the **Opening** and **Closing** times, and the **Break** (continuous or with lunch break).
2. Modify the days that changed and click **Save changes** ("Schedule saved"). **Reset values** restores the default schedule.

3. In **Exceptions and special days**, click **Add exception** to register a national holiday (closed all day) or special hours: choose the **Date**, the **Type**, the **Opening** and **Closing** times if applicable, and the **Reason / notes**, and click **Save exception**.
4. Use the **History** button to see the latest changes of the schedule.

A change applies to future availability; bookings already confirmed are not relocated automatically. Since October 24, 2026, if the new schedule or the exception would leave an active booking outside, the system does not save the change and shows how many bookings clash and their codes (*SCHEDULE_CONFLICTS_BOOKINGS*): first reschedule or cancel them in **Bookings** (section 12.3), contacting the customers, and then save the schedule.

Figure 6

Business Hours and Exceptions



11.3 Washing Bays

A bay is a physical washing spot, and the number of active bays defines the capacity of the business: two active bookings cannot occupy the same bay at overlapping times. A bay can be **Active**, **Under maintenance**, or **Inactive**; only active bays receive bookings.

1. Open **Hours & Bays > Wash bays**.
2. To create a bay, click **Add bay**, type the **Bay name**, choose the **Status**, and save.

3. For a repair, edit the bay and change its status to **Under maintenance**; it stops receiving new bookings.
4. Before putting a bay under maintenance or inactive, review the future bookings assigned to it and reschedule them. Since October 24, 2026, if active bookings remain on that bay, the system does not save the change and shows the clashing bookings.
5. When the repair is finished, return the status to **Active**.

11.4 Payment Methods and QR Codes

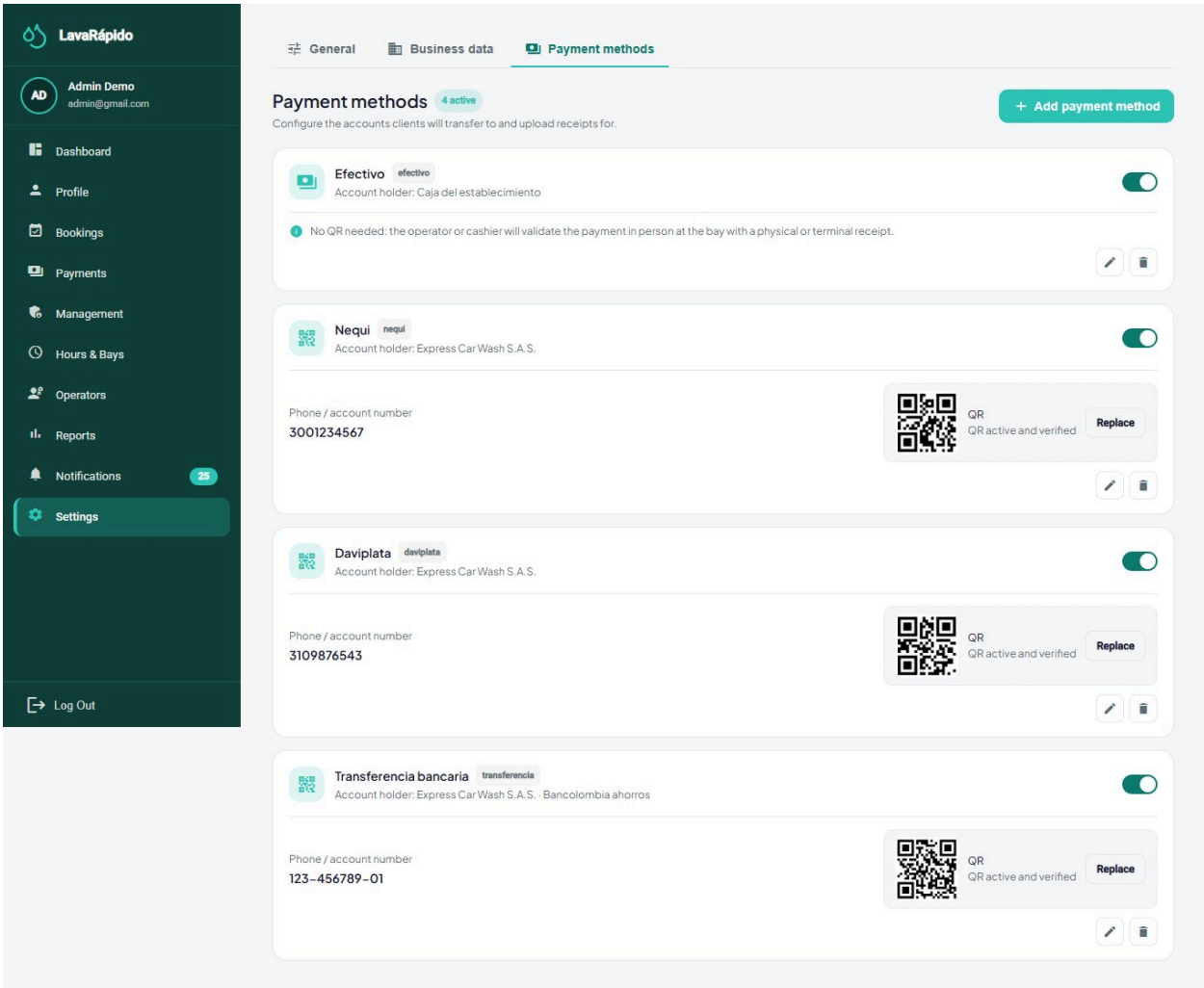
Settings > Payment methods manages the payment accounts of the business: for each account, the method (Nequi, Daviplata, or bank transfer), the holder, the account number, the QR image, the instructions, and whether it is active. Customers see only the active accounts. The cash account (*Caja del establecimiento*) appears in the same list and has no QR code; since October 21, 2026, if it is deactivated, the Cash option disappears from the customer payment screen; since October 24 the administrator still sees it in **Register manual payment** to collect at the counter. A wrong QR code or account sends the business's money to a third party, so this information must be reviewed carefully.

1. Open **Settings > Payment methods**.
2. Add an account or edit an existing one: method, holder, account number, QR image, and instructions.
3. Activate or deactivate the account depending on whether it is accepted.
4. From a test customer account, open **Pay service**, scan the QR code, and verify that the holder shown by the bank is the business.

The QR images and the receipts are stored inside the database as images (data URLs); there is no separate folder of files to back up (section 14.1).

Figure 7

Payment Methods Configuration



Note. Use a test account and QR code.

11.5 Platform Security Parameters

Table 8

Current Security Parameters

Parameter	Value	Where it is configured
Access token validity	1 hour; there is no refresh token	security-service (JWT_ACCESS_TOKEN_TTL).
Closed session	The token of a closed session (sign-out or deactivated account) stops working within 30 seconds (since October 21, 2026)	security-service and API Gateway (*SESSION_CHECK_**).
Account lockout after failed attempts	5 failed attempts within 15 minutes lock the account for 15 minutes; resetting the password unlocks it	security-service (*security.login_lockout*).
Recovery code	6 digits, valid for 15 minutes, single use. Since October 24, 2026, the 5th failed attempt voids the code and answers *TOO_MANY_ATTEMPTS*: another one must be requested	security-service.
Current password	Since October 24, 2026, mistakes when typing the current password (changing the password or the email, deactivating the account) count toward the same sign-in lockout: at the 5th, the account is locked for 15 minutes	security-service.
Request limit	Since October 24, 2026, 60 requests per minute per IP address on sign-in, sign-up, and recovery; beyond that, it answers *RATE_LIMITED* with the waiting time	API Gateway (*AUTH_RATE_LIMIT_**).
Consent	Since October 24, 2026 the server rejects a sign-up without the two data policy checkboxes (*CONSENT_REQUIRED*)	security-service.
Password	8 to 72 characters, one uppercase letter, one number, one special character, no spaces	security-service and web interface.
Password storage	BCrypt with cost factor 12	security-service.
Token signature	HS256 with a shared secret of at least 32 bytes	JWT_SECRET in the .env file.
Language and theme per user	Spanish, English, French, or Portuguese; four color themes	User preferences.

Note. Prepared by the authors from the configuration file of the security service and ADR-006.

11.6 Operating Environment Variables

The variables that change the behavior of the platform are read from the file *lavarapido-infra/.env* and require restarting the affected services. The most relevant for the IT administrator are *MESSAGING_ENABLED* (RabbitMQ events, also in payment-service), *MAIL_ENABLED* and *MAIL_** (email), *PUSH_ENABLED* (push notifications), *REMINDER_LEADS* (reminders, by default 24 h and 1 h), *BOOKING_ZONE* (time zone of the business), *BOOKING_SLOT_MINUTES* and *BOOKING_MAX_DAYS_AHEAD* (booking grid and window), *INTERNAL_API_KEY* (internal calls between services; since *develop* of October 23, 2026 the operator also needs it to start and finish services), *ALLOWED_EMAIL_DOMAINS* (email domains accepted by sign-up, *gmail.com* by default; sign-in accepts any domain since October 24, 2026), and *SPRING_PROFILES_ACTIVE* (profile of the Java services; with *dev*, the demonstration accounts whose password is in *DEMO_ADMIN_PASSWORD*, *DEMO_OPERATOR_PASSWORD*, or *DEMO_CLIENT_PASSWORD* are created). Those of October 21, 2026, *SESSION_CHECK_** (gateway session check), *BOOKING_EXPIRY_** (bookings that ended without being closed; *BOOKING_EXPIRY_GRACE_MINUTES* is used by booking-service and operations-service), and *FOLLOW_UP_** (check of the **To close** list in operations-service, including *FOLLOW_UP_LOOK_BACK_DAYS*, 28 days), have defaults and the Compose file passes them to the containers since October 22, 2026, so they are changed from *.env*. Since October 24, 2026 there are also *AUTH_RATE_LIMIT_** and *TRUSTED_PROXIES* (the gateway's sign-in request limit and trusted networks), *ROUTE_CONNECT_TIMEOUT* and *ROUTE_READ_TIMEOUT* (5 and 60 seconds per route), and *START_LATE_LIMIT* (how long after the end time the operator can still start, 4 hours); they have a default value and the compose file does not pass them yet. customer-service receives *INTERNAL_API_KEY* and *BOOKING_SERVICE_URL* to check a vehicle's active bookings before removing it. Since October 26, 2026 booking-service has *BOOKING_CASH_ACTIVE_LIMIT* (maximum active cash bookings per customer, 1), *BOOKING_PAYMENT_WINDOW* (deadline to upload the receipt of a booking with digital payment, 30 minutes), and *BOOKING_PAYMENT_EXPIRY_ENABLED* and

BOOKING_PAYMENT_EXPIRY_INTERVAL (cancellation of overdue digital bookings: on and every 60 seconds), which the compose file already passes to the container, and payment-service needs *INTERNAL_API_KEY*. Their values and the change procedure are described in the Installation Manual.

12. Management of Core Information

12.1 Operators and Availability

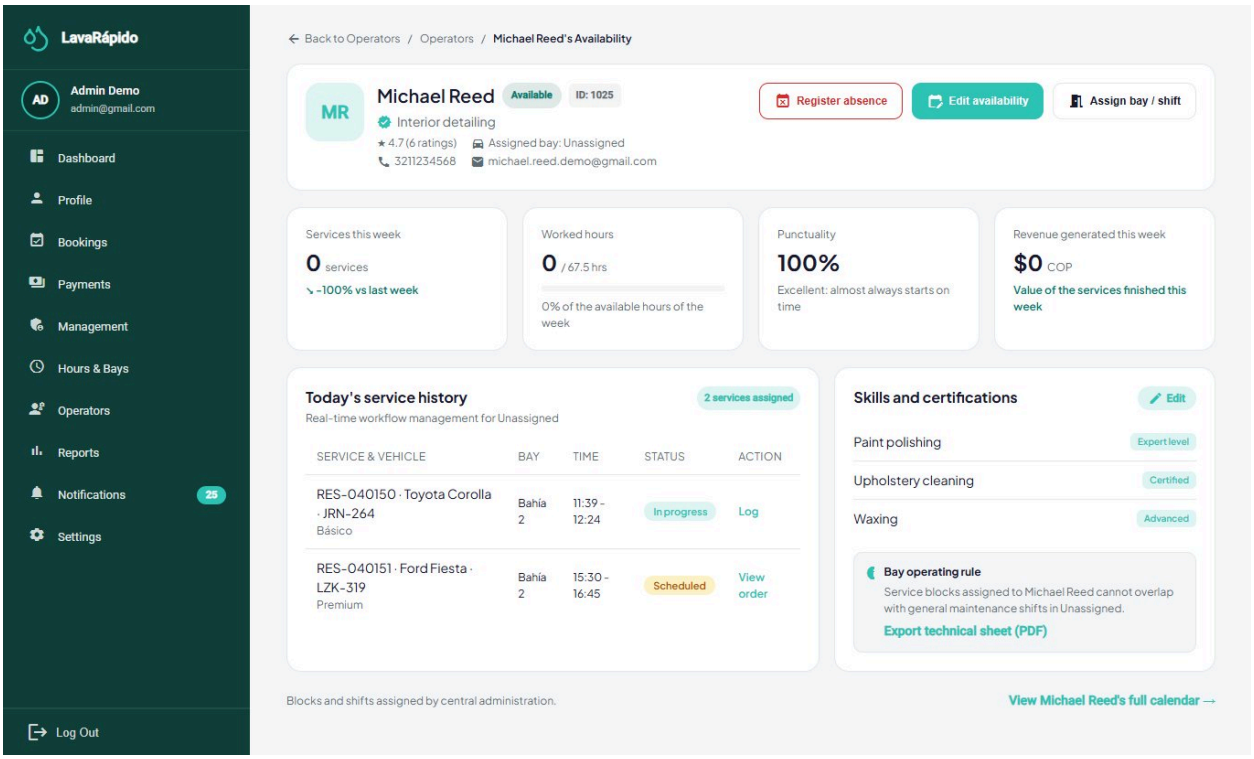
An operator is an account with the OPERATOR role that also has a record in *execution.operator*. The operations service creates that record automatically the first time it lists the operator accounts. The weekly availability (*execution.operator_availability*) defines the working hours of each day, and the absences (*execution.operator_absence*) block the operator between two dates; two absences of the same operator cannot overlap.

1. Open **Operators** (route */admin/operators*). Review the indicators and the cards of each operator; use the **All**, **Available**, **In service**, and **Absent** filters or the search box.
2. To add an operator, click **New operator**, fill in the account data (including a temporary password), and save.
3. Open an operator to see the detail (route */admin/operators/{id}*).
4. Click **Edit availability** to define, for each day, the **Start** and **End** of the shift; untick a day to mark it as a day off.
5. Click **Register absence** to record a leave with **Start date**, **End date**, and **Reason**.
6. Use **View full calendar** to see the week with available time, assigned services, leaves, and breaks.
7. To retire an operator, deactivate their account (section 9.4) and reassign their future services (section 12.4).

Some indicators of the detail screen (for example, punctuality, revenue goal, or skills) are illustrative and do not come from the server; the shifts, absences, services, and ratings do.

Figure 8

Operator Detail With Availability and Absences



12.2 Services, Prices, and Points

The catalog is organized in categories (washing, polishing, detailing, interior, and packages), services, and prices. Each price corresponds to a service and a vehicle type, with an amount and an estimated duration. Prices are immutable: when a price changes, the system closes the current price and creates a new one, so that existing bookings keep the price with which they were made.

1. Open **Management > Services**.
2. Click **Add service**, or edit an existing service.
3. Type the **Service Name**, the **Description**, and the **Category**.
4. In **Price and duration by vehicle type**, define the price in Colombian pesos (COP) and the estimated duration for each vehicle type (car, sedan, SUV, pickup, truck, and motorcycle). The price must be greater than 0: since October 24, 2026 the server rejects a price of 0 (*INVALID_PRICE*).

5. In **Loyalty points**, type the points the customer earns when the payment for this service is approved (a whole number; 0 = no points). The services table shows them in the **Points** column.
6. Click **Save Service**.
7. To stop offering a service, deactivate it ("It will no longer be available to book"); existing bookings are not altered.
8. Verify on the customer booking screen that the price, the duration, and the points shown are the new ones.

Each booking line keeps the points of the service at the moment of booking, in the same way as the price.

12.3 Bookings

The **Bookings** screen (route */admin/reservations*) lists the bookings with **Client**, **Vehicle & plate**, **Service**, **Date / time**, **Assigned operator**, and **Status**, together with indicators of the day (total, confirmed or in progress, awaiting operator, needs attention, and cancelled or rescheduled).

1. Use the search by client or plate, the date (**Today**), and the status and operator filters; **Clear** removes them.
2. To create a booking on behalf of a customer, click **New Booking**, look up the vehicle by plate, choose the services, the date, and a free time, and confirm.
3. Open a booking to see its detail. From there the administrator can reschedule it (another free date or time, and also other services), change its status (confirm, start, complete, mark as **No-show**), or cancel it by choosing a **Cancellation reason**. Each change asks for confirmation. Since October 24, 2026: if the booking already has a payment, changing its services shows a warning that the payment amount will no longer match (the old payment cannot be approved, section 12.6); setting the booking **In progress**, **Completed**, or **No-show** cancels the customer's pending reminders, and **No-show** sends them a notice; and if someone else changed the booking while it was open, the system rejects the change and the screen must be refreshed. Since October 26, 2026 the detail

shows the **Payment method** the customer chose: **Digital (QR and receipt)** or **Cash at the car wash**; bookings made before that day and those the administrator creates without stating it do not show it.

Payment at booking (since October 26, 2026). So that nobody blocks the schedule with bookings they do not intend to pay for, the customer chooses how they will pay when booking:

- **Digital payment:** the customer has 30 minutes (or until the start time, if that comes first) to upload the receipt. If they do not, the system cancels the booking with the reason **The payment receipt was not uploaded in time** (*PAYMENT_TIMEOUT*), frees the bay, and the customer receives the cancellation notice. That reason, like *EXPIRED*, is used only by the system and does not appear when cancelling by hand. Before cancelling, the system asks the payment service whether the booking already has a payment in review or approved; if it does, it does not cancel it.
- **Cash at the car wash:** the customer can have at most one active cash booking; the slot comes back when that booking is completed, cancelled, or marked No-show (not when the administrator records the payment). The administrator records the payment when the customer pays (section 12.6).
- A booking accepts at most 10 services (since October 27, 2026). If the chosen time is no longer free, the alternative times the system offers do not include those that overlap another booking of the same vehicle.
- Bookings the administrator creates with **New Booking** do not have to include a payment method and have no deadline or limit. Rescheduling a booking does not change its payment method or its deadline.
- Click **Export** to download the list in Excel, PDF, or CSV.

The life cycle rules are the same for everyone: a booking cannot fall outside the opening hours or occupy a bay that is already taken, and a booking that already started can no longer be canceled (Table 9).

Bookings that ended without being closed (since October 21, 2026). The system only closes a booking on its own when there is no doubt about what happened; in the other cases the administrator decides:

- Since October 24, 2026 every booking is created and rescheduled as **Confirmed**, so there is no longer a task that cancels expired **Scheduled** bookings (it was removed, B-07). An old booking still Scheduled becomes Confirmed if it is rescheduled.
- A **Confirmed** booking that never had an operator becomes **No-show** on its own one hour after its end, because nobody could serve it.
- A **Confirmed booking with an operator** that nobody started when its time ended, or an **In progress** booking that nobody finished one hour after its end, is never marked on its own: it goes to the **To close** card of the home screen. The operator receives the notice "¿Atendiste este servicio?" (did you serve this booking?) and every active administrator the notice "Servicio sin registrar" (service not recorded) (section 12.7).

This rule replaced the first version of the same day, which closed as No-show every booking that nobody started: if the operator washed the vehicle and forgot to press **Start**, the record said that the customer did not come. The system never makes refunds: if the booking was paid, the administrator reviews the payment in **Payments** (section 12.6).

To close the pending bookings:

1. Find the **To close** card on the web **Dashboard** or on the home screen of the mobile app. It only appears when there is a pending booking and shows those of the last 28 days (*FOLLOW_UP_LOOK_BACK_DAYS*), because the server can stay off for weeks.
2. Check with the operator whether the vehicle was served. Up to 4 hours after the end time (*START_LATE_LIMIT*, since October 24, 2026), the operator can record the service with **Start** and **Finish** even if it is late; this keeps the real hours and the booking leaves the list. After that, their **Start** button is disabled and the administrator closes it.
3. If the vehicle was served, click **Attended**. The booking becomes Completed without made-up hours: without a start time it does not count toward the operator's punctuality

and without an end time it does not add worked hours, but it does count as a service done and as income. The customer does not receive the notice that the vehicle is ready for pickup (it would arrive hours late), but can still rate the service.

4. If the customer did not come, click **No-show**. This option only applies to a booking that was never started, and the status is final.
5. If a message says that the booking is no longer to close, another administrator or the operator closed it first; just refresh the screen.

Table 9

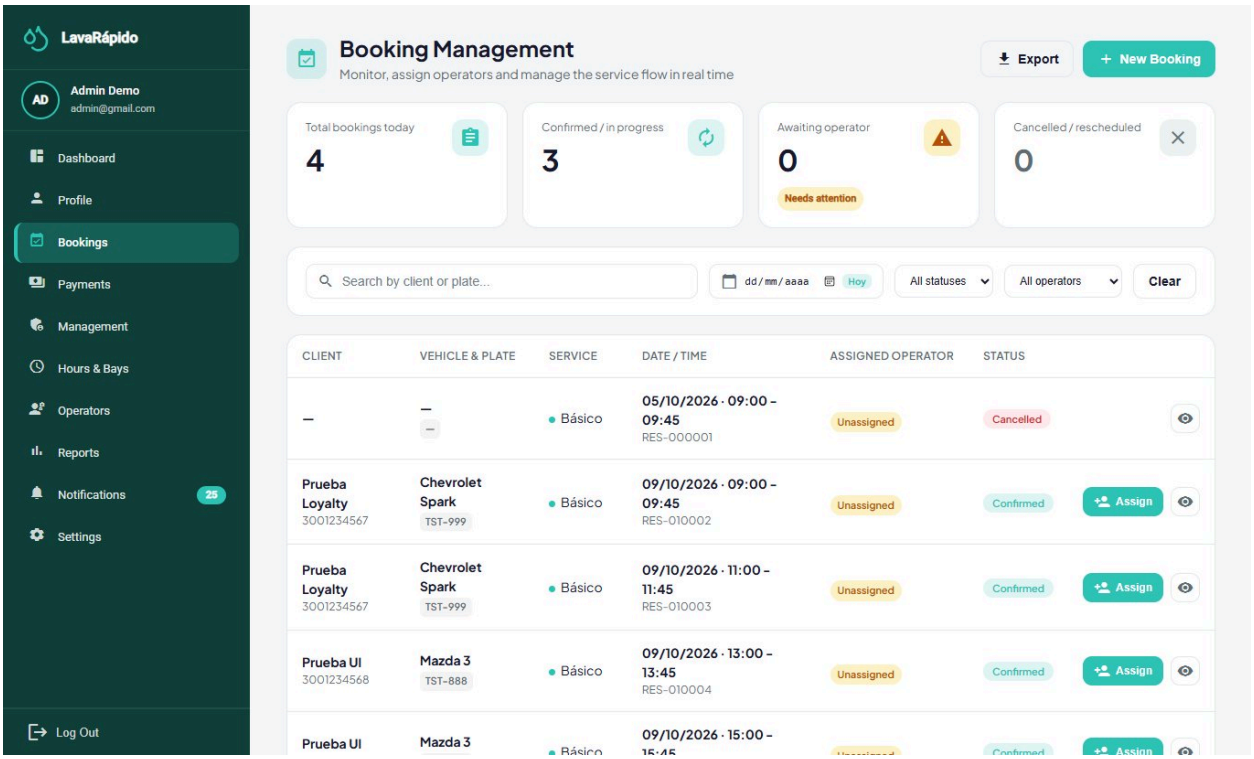
Booking Statuses and Administrator Action

Status	Meaning	Possible administrator action
SCHEDULED	Registered and pending confirmation.	Confirm, assign an operator, or cancel.
CONFIRMED	With a slot and a bay. Bookings made by customers start here.	Assign or change the operator, reschedule, or cancel.
IN_PROGRESS	The operator started the wash.	Supervise; it can no longer be canceled.
COMPLETED	Service finished.	Verify or record the payment.
CANCELLED	Voided by the customer or the business (until October 23, 2026 the system also closed expired scheduled bookings this way). Since October 26, 2026 the system cancels this way a booking with digital payment whose receipt did not arrive in time (*PAYMENT_TIMEOUT*).	Check the reason.
NO_SHOW	The customer did not arrive (marked by the administrator), or the confirmed booking ended one hour ago without an operator (marked by the system).	Record it, review patterns and, if the customer had paid, decide on the refund.

Note. Database codes according to ADR-010; the interface translates them.

Figure 9

Booking Management



12.4 Assigning an Operator

When a booking is confirmed, **the system assigns the operator automatically** (RF-008): if the customer chose one who is still free, that operator is assigned; otherwise, the free operator with the fewest bookings that day. An operator is free when the account is active, has a shift at that time, has no recorded absence, and is not serving another booking at that time. If nobody is free, the booking is left without an operator and appears in the **Bookings without an operator** block of the Dashboard. Since October 21, 2026 the Dashboard and the **Bookings** screen, on the web and in the mobile app, use the same count: scheduled or confirmed bookings, with no operator on any service, whose time has not ended yet. A rescheduled booking keeps its operator. The administrator assigns by hand in two cases: when the booking was left without an operator and when the assigned one must be changed.

1. In the **Dashboard** (block **Bookings without an operator**) or in **Bookings**, click **Assign** on the booking.

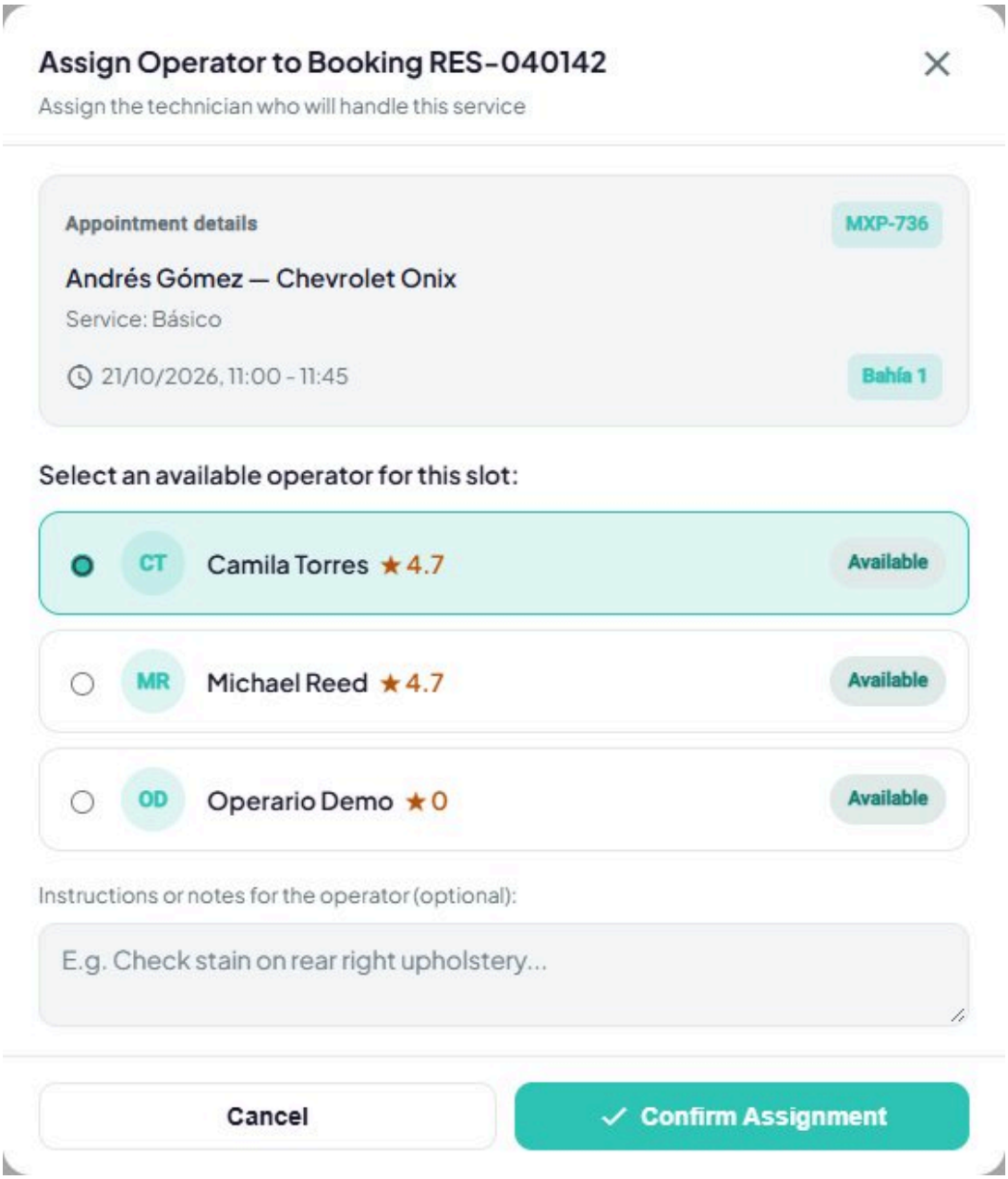
2. The window "Assign Operator to Booking [code]" shows the details of the appointment and the list of operators. The available operators appear first; the others show why they cannot take the booking: **Inactive**, **No shift at that time**, **Absent**, or **Busy at that time**.
3. Select an available operator and, if desired, write instructions for the operator. Since October 24, 2026 the operator sees those notes in the service detail, on the web and in the app; if the booking is reassigned without notes, the previous ones are kept.
4. Click **Confirm Assignment**. The message "Operator assigned" appears and the operator receives a notification. If the booking already had another operator, that operator receives the notice that the service was reassigned.

The assignments list shows the bay of each booking next to its operator, so the administrator can see which operator is working in which bay. Operators are not tied to a bay for a whole shift: the bay is chosen per booking (ADR-010 and ADR-015).

Only bookings in SCHEDULED or CONFIRMED status can be assigned, and the operator can be changed while no line of the booking has started. If an operator who is not eligible is chosen, the server rejects the assignment and explains the reason. If the automatic assignment and a manual one happen at the same time, the system runs them one after the other, so an operator does not end up with two services at the same time.

Figure 10

Manual Assignment of an Operator



12.5 Vehicle Inspection Report

For long services (180 minutes or more), the administrator can record the condition of the vehicle by phases (Reception, Exterior, Interior, Engine, and Delivery) with findings and photos, and share the report with the customer through a link.

1. In **Bookings**, open the booking and choose the inspection option (route */admin/reservations/{id}/inspection*).
2. Click **Start report** when the vehicle arrives.
3. In each phase, click **Start phase**, add the findings with **Add finding** (vehicle part, type: note, minor damage, or major damage; description; and up to five JPG or PNG photos of up to 10 MB), and click **Finish phase**.
4. Click **Publish and copy link**; **View as customer** shows the public version (route */report/{token}*).
5. Click **Notify customer**. The system sends the customer a notification and an email (type *INSPECTION_REPORT*) with the summary of the inspection: phases finished, number of findings, major findings, and affected areas, together with the link to the report. The message "Customer notified" confirms the sending.

From the mobile app. The report can also be managed from the phone, with the same phases and the same server rules:

1. In **Bookings**, tap the eye icon of the booking and, in the detail, tap **Inspection**. The button only appears for services of 180 minutes or more that are confirmed, in progress, or completed.
2. Tap **Start report** and, in each phase, **Start phase**, **Add finding**, and **Finish phase** (or **Reopen** to correct a finished phase).
3. In **New finding**, type or choose the vehicle part from the suggestions, choose the type, and write the note. Attach up to five photos with **Take photo** (camera) or **Gallery**. The app shrinks each photo to 1600 pixels on its longer side, in JPEG format, before uploading it, because the server accepts at most 2 MB per photo.
4. Tap **Publish and share link**. The report is published and, from then on, **Share link** opens the phone share menu (WhatsApp, email, or copy). **Notify customer** sends the same notice as the web, and **View as customer** opens the public link in the browser.

The first time, the phone asks for permission to use the camera and the photos; if the permission is denied, the screen says it must be enabled in the phone settings. Saved photos are shown as thumbnails and are enlarged when tapped.

Where it is saved: the report, its phases, the findings, and the photos are saved in operations-service (tables *execution.inspection_report*, *execution.inspection_phase*, *execution.inspection_finding*, and *execution.inspection_photo*). The photos are shrunk before they are sent: in the browser when the web is used and on the phone when the mobile app is used. The public link (route */report/{token}*) only works after the report is published and opens from any device without logging in, which is why the notice to the customer includes it.

12.6 Payment Review and Approval

The system does not integrate a payment gateway (ADR-008). The customer pays outside the platform with the business's QR code and uploads the receipt; the administrator verifies that the money arrived and approves or rejects the payment. It is the most sensitive function of the role, because it authorizes the charge for a service (Table 10).

Table 10

Payment Review Controls

Control	How the system applies it	What the administrator must do
Amount	The amount due is the booking total calculated by the server minus the coupon redeemed, if any; the customer declares the amount paid, and the review window compares both. Since October 24, 2026, if the booking changed after the customer reported the payment (other services or another total), approving answers *AMOUNT_CHANGED*.	Compare the declared amount and the receipt with the amount due; on *AMOUNT_CHANGED*, reject the payment so the customer reports it again with the current amount.
Single approved payment	A booking does not admit more than one approved payment, and a second payment cannot be reported while one is in review; since October 24, 2026 the database also guarantees it against two simultaneous reports.	Do not try to approve a second payment for the same booking.
Transaction reference	The system rejects a reference already used in another payment (*TRANSACTION_REFERENCE_REUSED*); since October 24, 2026 the database guarantees it among live payments.	Verify that the reference of the receipt matches the bank movement.
Real verification	The system does not query the bank.	Confirm in the app or statement of the business that the money arrived; do not rely only on the image.
History	Rejected payments are kept with their reason.	Do not delete rejected attempts.
Cancelled booking	Since October 24, 2026, if a payment's booking was cancelled, the payment shows the "Booking cancelled" notice: **refund** it if approved or **reject** it if in review.	Return the money or reject the payment, as the notice says.
Receipt size	The server rejects receipts larger than 2 MB (*RECEIPT_TOO_LARGE*); the web and the app reduce them before sending them.	If an image looks blurry, ask the customer for a screenshot of the receipt.

Note. Prepared by the authors from the payment service and ADR-008.

Approving a digital payment.

1. Open **Payments** (route */admin/payments*) and filter by **Pending validation**.
2. Click **Review** on the payment. The window "Review payment [code]" shows the attached receipt, the linked booking, the service and vehicle, the operator, the method, the reference, and the **Amount comparison** between the **Amount due (service)** and the

Amount declared on receipt. If they differ, the window shows "The amounts don't match"; if the customer did not declare the amount, verify it directly on the receipt image.

3. Verify that the money arrived in the business's account with that amount and reference.
4. Click **Approve payment**. The payment changes to Approved, the customer receives the notice and the email "Payment confirmed", and the loyalty points of the booking are credited (with a notice for each coupon those points unlock).

Rejecting a payment. If the money did not arrive, the receipt is illegible, or the amount does not match, click **Reject**, type the **Rejection reason** (maximum 200 characters), and confirm. The customer receives a notice and an email with the reason and can report the payment again.

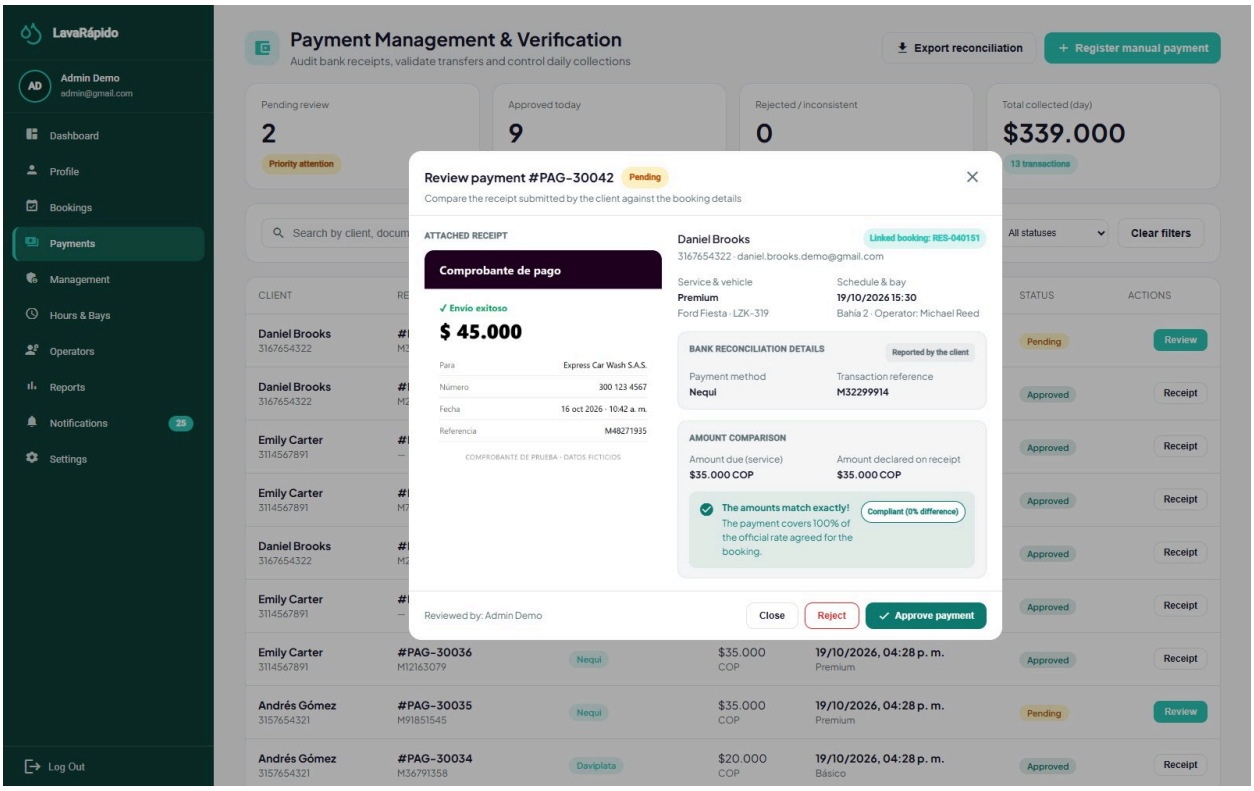
Recording a cash or counter payment. Cash is always recorded by the administrator: the customer does not upload a receipt and, since October 26, 2026, a booking the customer made in cash shows **Cash at the car wash** as the payment method in its detail. Click **Register manual payment**, choose the booking and the method, and confirm. The cash account appears even if it is deactivated for customers (since October 24, 2026). The window shows the real amount due of the booking (with the coupon discount, if any), and the manual payment is approved immediately with that amount and credits the points. Use it only when the money was received.

Refunding a payment. Open an approved payment and click **Refund**. Confirm that the money was returned to the customer: the payment changes to Refunded, the points that the booking earned are reversed, and the customer receives a notice and an email. The refund cannot be undone.

Export reconciliation downloads the list in Excel, PDF, or CSV. Customer notices require *MESSAGING_ENABLED=true* in payment-service and notification-service.

Figure 11

Payment Review



Note. Use a test receipt, without real bank data.

12.7 Notifications and Announcements

The **Notifications** option of the administrator works like that of the other roles: it lists the notifications with filters and allows marking them as read or deleting them. Clicking a notification opens its detail and marks it as read; booking notices bring the **Go to bookings** button and the welcome notice **Go to home**. Every active administrator receives staff notices in the inbox and as push notifications (never by email): a new booking confirmed, a booking moved to another time, a booking cancelled (with the reason) and, since October 21, 2026, the notice "Servicio sin registrar" (service not recorded) when a booking with an operator ended and nobody started or finished it. That notice arrives only once per booking and opens the home screen, where the booking appears in **To close** (section 12.3).

Announcements are sent with *POST /api/v1/admin/notifications* (ADMIN role), which accepts only two types: *SYSTEM_MESSAGE* (free announcement, inbox and push only; available only through the API, because the panel does not have a screen for it) and *INSPECTION_REPORT* (sent from the inspection screen, also by email). Any other type is rejected with 400 *NOTIFICATION_TYPE_NOT_ALLOWED*, so that nobody can write by hand a notice that looks like an automatic one (for example, a false approved payment). The message is always saved in the inbox of the recipient; the push notification is additional (it requires *PUSH_ENABLED=true* and the mobile application) and respects the switches of each user.

12.8 Promotions and Loyalty

Loyalty points. Each service has its own points (section 12.2). When the administrator approves a payment or records a manual payment, payment-service credits the points of the booking in the ledger *payment.loyalty_transaction* (once per booking); a refund reverses them. The balance of a customer is always that of their last ledger movement, and points are never spent.

Promotions. The **Management > Promotions** tab manages the discount coupons that customers unlock with their points (data saved in payment-service, *GET*, *POST*, *PUT*, *PATCH*, and *DELETE /api/v1/admin/promotions*):

1. Click to create a promotion and type the **Name**, the **Description**, the **Coupon** code (for example, PREMIUM20), the icon, the benefits, and the **Start date** (if it is in the future, the promotion stays scheduled until that day).
2. Type the **Discount on redemption (%)**, between 1 and 99 (if the promotion has a fixed discount in pesos, *FIXED*, the card shows it in pesos and editing it keeps the type, since October 24, 2026), which is applied to the booking total when the customer redeems the coupon. There are no 100 % coupons: the payment requires an amount greater than zero, so the system always leaves at least 1 peso to pay, also with a fixed discount larger than the total (since *develop* of October 23, 2026, E-07).
3. Type the **Loyalty points required** to unlock the coupon (0 = available to everyone).

4. Save. The card of the promotion shows the discount ("N% off") and the points needed ("unlocks at N points" or "available to everyone"). The status is calculated from the start date and can be paused or resumed from the card.

When the points of a customer reach those required by an available coupon, the customer receives the notice "You have a redeemable coupon!" with its code. Redeeming a coupon does not consume points, and each coupon can be redeemed once per booking.

13. Administrative Reports

The **Reports** screen (route */admin/reports*) shows the performance of the business with data of bookings and payments loaded from the server:

1. Choose the filters **Date**, **Service**, and **Operator** and click **Apply filters**.
2. Review the **Charts** of services completed and revenue for the period. Since October 21, 2026 the cards and the charts count only completed bookings as services done.
3. Review the summaries **Today's Report**, **Week's Report**, and **Month's Report** (services completed and total revenue), the **Year's Total Revenue**, and the **Best-Selling Services**.
4. Click **Export report**, choose the period (day, week, or month), preview it, and download it with **Export Excel** or **Export PDF**.

For queries that the screen does not offer, the IT administrator can use the support queries of section 13.1 (Table 11).

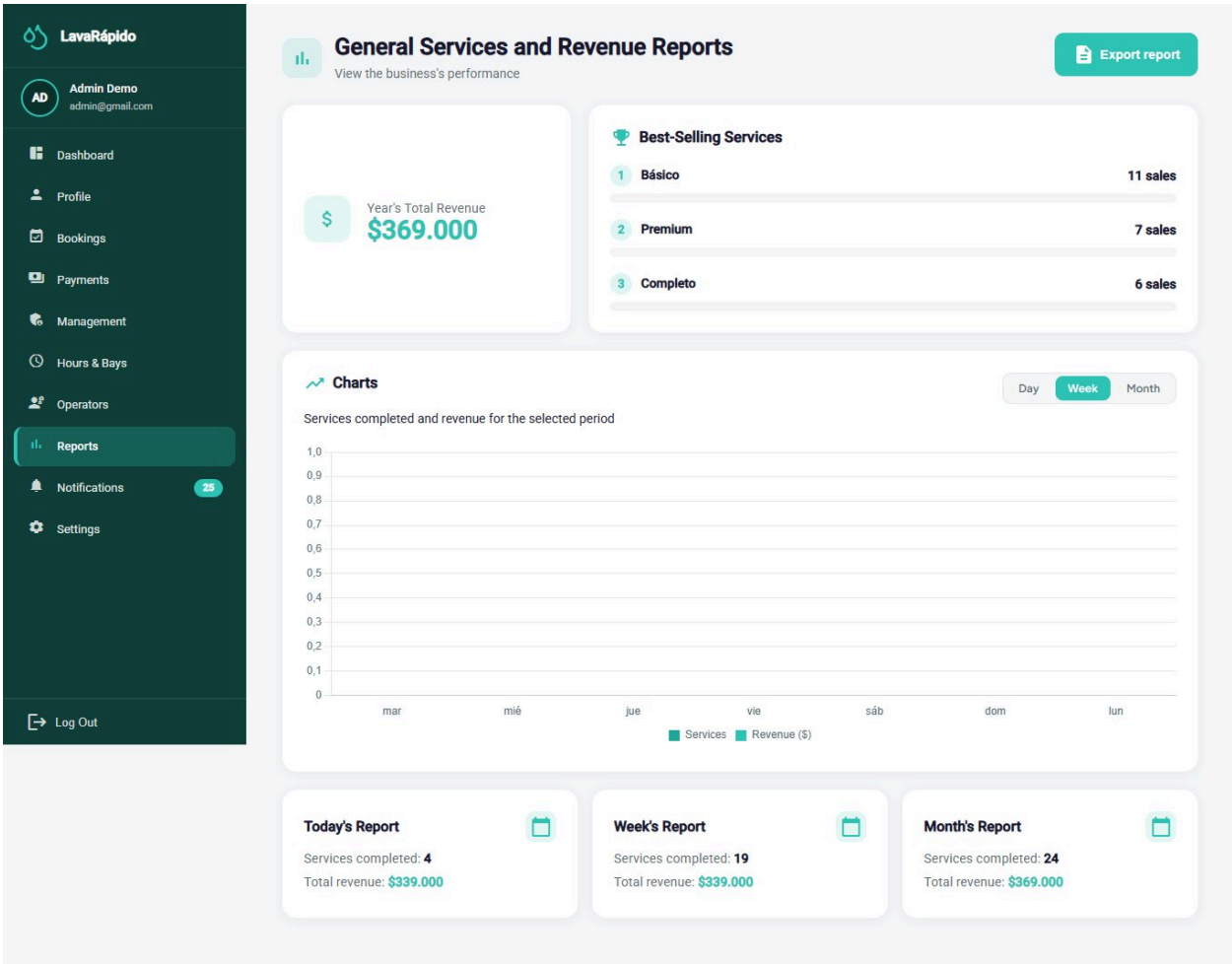
Table 11

Administrative Indicators and Data Sources

Indicator	Content	Data source
Services performed	Services completed by period, service, and operator.	booking.booking and execution.service_execution
Revenue	Approved payments by day, month, and account.	payment.payment
Average rating	Average of the ratings per operator.	execution.service_execution
Payments by status	Number and amount of payments in each status.	payment.payment
Loyalty points	Point movements and balances per customer.	payment.loyalty_transaction
Users	Accounts by role and status.	security.app_user and security.user_role

Figure 12

Administrative Reports



13.1 Support Queries

Approved revenue per day (dates are stored in UTC; for the Colombian calendar day, five hours are subtracted before converting to a date):

```
SELECT CAST(DATEADD(hour, -5, p.processed_at) AS date) AS business_day,
       COUNT(*)      AS payments,
       SUM(p.amount) AS revenue
FROM payment.payment p
JOIN payment.payment_status ps ON ps.payment_status_id = p.payment_status_id
WHERE ps.code = 'APPROVED'
  AND p.processed_at >= DATEADD(day, -30, SYSUTCDATETIME())
GROUP BY CAST(DATEADD(hour, -5, p.processed_at) AS date)
ORDER BY business_day DESC;
```

Performance per operator:

```
SELECT o.operator_id, o.user_id,
       COUNT(*)                              AS services_completed,
       AVG(CAST(se.quality_rating AS float))  AS average_rating,
       COUNT(se.quality_rating)               AS rated_services
FROM execution.service_execution se
JOIN execution.operator         o  ON o.operator_id = se.operator_id
JOIN execution.execution_status es ON es.execution_status_id = se.execution_status_id
WHERE es.code = 'COMPLETED' AND se.deleted_at IS NULL
GROUP BY o.operator_id, o.user_id
ORDER BY services_completed DESC;
```

Payments pending review, the most urgent indicator of the day:

```
SELECT p.payment_id, p.booking_id, p.amount, r.transaction_reference, r.uploaded_at
FROM payment.payment p
JOIN payment.payment_status ps ON ps.payment_status_id = p.payment_status_id
LEFT JOIN payment.payment_receipt r ON r.payment_id = p.payment_id
WHERE ps.code = 'IN_REVIEW'
ORDER BY r.uploaded_at;
```

Transaction references used more than once (the system rejects them since October 8, 2026; the query detects older duplicates):

```
SELECT r.transaction_reference, COUNT(*) AS times_used
FROM payment.payment_receipt r
WHERE r.transaction_reference IS NOT NULL
GROUP BY r.transaction_reference
HAVING COUNT(*) > 1;
```

The queries are read-only. They must be run with a query account, outside peak hours if the database is large, and their results must not be copied to shared spreadsheets without authorization, because they contain personal data.

14. Backups

The project documentation does not define a backup strategy, because production is outside its scope, and the application does not include a backup module. Therefore, backups are a task of the IT administrator on SQL Server and the Docker volumes. On the public server, since October 21, 2026, that task is automated with the *lavarapido-infra/deploy* scripts (section 14.6); sections 14.1 to 14.5 apply to a local computer and help understand what those scripts do. This section proposes a procedure based on contingency planning practices (Swanson et al., 2010) and on the SQL Server

documentation (Microsoft, n.d.). The values marked as recommendations must be approved by the team (Annex B).

14.1 What Must Be Backed Up

Table 12

Items That Must Be Included in the Backup

Item	Content	How it is backed up
Database *LavaRapido*	The nine schemas, the QR images and receipts (stored as data URLs), and the Liquibase control tables of each service.	Full BACKUP DATABASE.
File *lavarapido-infra/.env*	JWT secret, passwords, and environment variables.	Encrypted copy kept apart from the data backups; never in a repository.
Volume *rabbitmq-data*	Queues and pending messages of RabbitMQ.	Optional; messages are transient.
Environment definition	*docker-compose.yml* and code repositories.	Already versioned in Git; verify that the remotes are up to date.
Business data and inspection reports	Since October 15, 2026 they are stored in booking-service and operations-service, inside *LavaRapido* (section 6.3).	Included in the BACKUP DATABASE.

Note. Recommendations of this manual. A database restored without its *.env* file cannot be used by the services.

14.2 Recommended Policy

Table 13

Recommended Backup Policy

Aspect	Recommendation
Frequency	One full backup per day outside business hours, and another immediately before each migration or major change.
Retention	14 daily, 8 weekly, and 12 monthly backups.
3-2-1 rule	Three copies, on two different media, one of them outside the machine where the system runs.
File name	backup_LavaRapido_YYYY-MM-DD_HHMM.bak (for example, backup_LavaRapido_2026-10-07_0200.bak).
Encryption and access	Store the copies in a folder with restricted access and encrypt those that leave the machine: they contain personal data protected by Law 1581 of 2012.
Recovery objectives	Maximum acceptable data loss (RPO): 24 hours. Maximum recovery time (RTO): 4 hours.
Verification	Check each backup and restore one in a test environment at least once a month.

Note. Recommendations of this manual; they do not come from the project documentation.

14.3 Generating a Manual Backup

On the server the backup is made with the team's script *lavarapido-infra/deploy/backup-db.sh*, the same one the daily task and *update-server.sh* run (Deployment Document, section 3.2). Do not write a *BACKUP DATABASE* by hand: the server uses SQL Server **Express**, which does not support the *COMPRESSION* option (the command fails), and the script already does everything needed: full backup with a checksum (*CHECKSUM*), *RESTORE VERIFYONLY*, compression with *gzip* outside SQL Server, restricted permissions, and retention of the last 14. The script itself reads the *sa* password from *lavarapido-infra/.env.production* and gives it to *sqlcmd* in the *SQLCMDPASSWORD* variable, not with *-P*, so there is no need to pass it or write it anywhere.

1. Verify that there is free disk space (a backup occupies, as an order of magnitude, the size of the data).
2. Generate the backup and check that it can be restored.
3. Copy it to secure storage outside the virtual machine.

4. Record the backup (date, file, size, verification result, and person responsible); the script already writes it to *~/lavarapido/backups/backup.log*.

```
# 1) Backup: leaves ~/lavarapido/backups/LavaRapido-YYYYMMDD-HHMMSS.bak.gz
bash ~/lavarapido/lavarapido-infra/deploy/backup-db.sh

# 2) Proof that the latest backup can be restored (restores it under another name and
drops it)
bash ~/lavarapido/lavarapido-infra/deploy/verify-backup.sh

# 3) Result of both
tail -n 5 ~/lavarapido/backups/backup.log
```

On a local installation with the development compose file (SQL Server Developer and no *.env.production*) the script does not apply; the backup is generated inside the container **without** *COMPRESSION*, so the same command also works on Express. The *CHECKSUM* option detects damaged pages when backing up and when verifying:

```
cd lavarapido-infra
docker compose exec -e SQLCMDPASSWORD="$DB_PASSWORD" sqlserver /opt/mssql-
tools18/bin/sqlcmd -S localhost -U sa -C -b -Q \
  "BACKUP DATABASE [LavaRapido] TO DISK = N'/var/opt/mssql/data/backup_LavaRapido.bak'
WITH INIT, CHECKSUM"
docker compose exec -e SQLCMDPASSWORD="$DB_PASSWORD" sqlserver /opt/mssql-
tools18/bin/sqlcmd -S localhost -U sa -C -b -Q \
  "RESTORE VERIFYONLY FROM DISK = N'/var/opt/mssql/data/backup_LavaRapido.bak' WITH
CHECKSUM"
docker cp lavarapido-sqlserver:/var/opt/mssql/data/backup_LavaRapido.bak ./backups/
```

Figure 13

Backup Generated and Verified



14.4 Automating the Daily Backup

A backup that depends on someone remembering it ends up not being made. On the server there is no script or *cron* task to write: *setup-server.sh* already schedules in the *azureuser crontab*,

every day at 23:00 UTC and 5 minutes after each start of the virtual machine, *backup-db.sh* followed by *verify-backup.sh*, and each run is written to *~/lavarapido/backups/backup.log*. The task reads the password from *.env.production*, so it does not depend on *DB_PASSWORD* being in the *cron* environment and does not pass it with *-P* (the sample script that used to be in this section failed when it ran on its own and used *COMPRESSION*).

```
crontab -l | grep backup-db.sh              # the task scheduled by setup-server.sh
grep RESPALDO ~/lavarapido/backups/backup.log | tail -n 3
```

On a local Windows computer the same idea is scheduled with the Task Scheduler, running the local block of section 14.3 with the password taken from *.env* and not written in the script. Its result must be monitored: an alert when the file of the day does not exist is worth more than many backups that nobody checks. The backups stay on the same disk as the virtual machine; to have a copy outside, download them to the team's PC (Deployment Document, section 3.2).

14.5 Backup Before Changes

- Before deploying a new version of a service (each Java service applies its Liquibase migrations when it starts) or running the *payment-migrate* container, make a backup.
- Before bulk changes of roles, prices, or assignments, make a backup.
- Do not run *docker compose down -v* in an environment with data that matters: it deletes the database volume.

14.6 Automatic Backups of the Public Server

Since October 21, 2026 the public server backs up the database without intervention (Deployment Document, section 3.2):

- *deploy/backup-db.sh* takes a full backup with a checksum, checks that it can be restored, and stores it compressed in *~/lavarapido/backups/*, with permissions for its owner only (600). The last 14 are kept.
- It runs before every update (if it fails, *update-server.sh* does not update), 5 minutes after the virtual machine starts, and every day at 23:00 UTC (6:00 p.m. in Colombia) if it is on.

- After each scheduled backup, *deploy/verify-backup.sh* restores it under another name, checks that it has the tables of the real database, and drops it. This way the restoration test of section 14.2 is done every day, without touching the real database.
- Every backup, check, and restore is written to *~/lavarapido/backups/backup.log*: *tail -20* shows the latest and *grep FALLÓ* only the problems.
- The database uses the SIMPLE recovery model: with full backups no transaction log backups are needed, and the log does not grow without limit.
- The backups live on the same disk as the virtual machine: they protect against an error or a bad migration, not against losing the machine. To meet the 3-2-1 rule of Table 13, copy them to the IT administrator's computer with *scp* or take a disk snapshot in Azure.
- Since October 24, 2026 the *LavaRapido-pre-update-…* backups that each update makes are kept separately (the last 10), besides the 14 regular ones, and after a healthy update unused Docker images are deleted so the disk does not fill up.
- **Continuous deployment (active since October 26, 2026).** Every approved merge into *main* deploys on its own (Deployment Document, sections 1.3.12 and 4.3.4). Since that day *setup-server.sh* adds a second *@reboot* task to the same *crontab*, *deploy/boot-update.sh*, which, when the machine is turned on, pulls what entered *main* while it was off and deploys it with *update-server.sh*, which backs up first. If the server is on *develop* (as it was until *v1.1.0*, published on October 26, 2026), that task does not update: the protection that prevents downgrading stops it without touching anything. Its result is written to *~/lavarapido/backups/deploy.log* and is checked with *crontab -l | grep boot-update*. If the prior backup fails, nothing is updated. The details are in the Deployment Document, section 4.3.4.

15. Data Restoration

Restoring overwrites the current data with those of the backup: everything recorded after it is lost. For that reason, restoration must be an authorized and recorded decision, never an improvised reaction.

15.1 When to Restore

Table 14

Restoration Scenarios

Scenario	Decision
Damaged database or container lost without its volume	Full restoration from the last valid backup.
Erroneous bulk change (for example, prices or roles)	Restore into a temporary database, extract the correct data, and correct the real database; avoid overwriting it if there is new data.
Failed migration	Restore the backup prior to the migration and review the changeset.
Security compromise	Restore in a clean environment and change the secrets and passwords before reopening access.
Periodic test	Restore in a test environment, never over the real one.

15.2 Full Restoration Procedure

1. Obtain authorization and announce the interruption to the users.
2. Choose the backup and check its integrity with RESTORE VERIFYONLY.
3. Stop the application services and the gateway so that they do not write during the restoration; leave SQL Server running.
4. Make a backup of the current state, even if it is damaged, so as not to lose the evidence.
5. Copy the backup file into the container and restore it.
6. Verify the structure and the data (section 15.3).
7. Start the services and run the verification tests of the Installation Manual.
8. Record the restoration and tell the users the date and time of the last recovered data.

```
cd lavarapido-infra
# Stop the application containers (the database stays running)
docker compose stop api-gateway security-service customer-service booking-service \
  operations-service payment-service notification-service

# Copy the backup into the container
docker cp ./backups/<FILE>.bak lavarapido-sqlserver:/var/opt/mssql/data/

# Restore (closes open connections and replaces the database)
docker compose exec sqlserver /opt/mssql-tools18/bin/sqlcmd \
  -S localhost -U sa -P "$DB_PASSWORD" -C -b -Q \
  "ALTER DATABASE [LavaRapido] SET SINGLE_USER WITH ROLLBACK IMMEDIATE;
   RESTORE DATABASE [LavaRapido] FROM DISK = N'/var/opt/mssql/data/<FILE>.bak' WITH
REPLACE, CHECKSUM, STATS = 10;
   ALTER DATABASE [LavaRapido] SET MULTI_USER;"
```

On the public server, *bash ~/lavarapido/lavarapido-infra/deploy/restore-db.sh <FILE>.bak.gz* is used: it asks to type RESTAURAR, first backs up the current database, stops the seven services, restores, and starts them again (2 to 3 minutes of downtime). Since October 24, 2026 it requires a terminal, takes the same lock as the updates, shows the backup's date before confirming, runs *payment-migrate* at the end, and never leaves the services stopped. It is better to restore a recent backup: the safety backup it makes first applies the 14-file retention and could delete the chosen file if it is the oldest one (ACO-37). With *--as LavaRapido_prueba* it restores under another name, without touching the real database, to inspect a backup. The *WITH REPLACE* option overwrites the existing database: use it only when you are sure of the chosen backup. If the command fails halfway, the database may remain in a restoring state or in single-user mode; do not restart the container without reviewing the SQL Server log.

15.3 Post-Restoration Verification

- The nine schemas exist and the catalog tables have their rows (queries of the Installation Manual, section 11).
- The fixed identifiers are still in place: *booking_status_id = 5* (CANCELLED) and *payment_status_id = 3* (APPROVED).
- The last booking and the last session correspond to the expected date of the backup.
- An administrator can log in, and a test customer can consult the bookings.

- The tables *DATABASECHANGELOG_** of each service reflect the last changeset applied in that backup.

Payments transferred to the business's account and not recorded because of the restoration must be compared with the bank statement and recovered with the customers.

15.4 Rolling Back a Migration

Liquibase changesets are forward-only. Undoing a migration therefore means restoring the previous backup and correcting the change with a new changeset; an already executed changeset must never be edited.

Going back to the previous version of the services (since October 24, 2026). Before rebuilding, *update-server.sh* keeps the running version as *:prev*. If an update leaves something broken, the IT administrator logs into the server with *ssh -t* and runs *bash ~/lavarapido/lavarapido-infra/deploy/rollback.sh* (all services) or *rollback.sh web* (only some): it shows the date of the previous version, asks to type VOLVER, recreates the containers without building, waits up to 8 minutes for them to be healthy, and logs it in *backups/deploy.log*. It does not touch the database: if the bad version applied a migration, the *LavaRapido-pre-update-…* backup must also be restored (section 15.2). Then the change is reverted on GitHub. If a contract changed between the two versions (for example, the web's port), going back may leave that service down (ACO-37).

Figure 14

Post-Restoration Verification

sqlcmd — LavaRapido

```
1> SELECT s.name AS [schema], COUNT(*) AS tables
2> FROM sys.tables t JOIN sys.schemas s ON s.schema_id = t.schema_id
3> WHERE s.name IN ('security','audit','customer','catalog','booking',
4>                  'execution','promotion','payment','notification')
5> GROUP BY s.name ORDER BY s.name;
6> GO
schema        tables
------------  ------
audit         1
booking       10
catalog       3
customer      3
execution     11
notification  6
payment       7
promotion     5
security      11

1> SELECT booking_status_id, code FROM booking.booking_status WHERE booking_status_id = 5;
2> SELECT payment_status_id, code FROM payment.payment_status WHERE payment_status_id = 3;
3> GO
booking_status_id  code
-----------------  ---------
5                  CANCELLED

payment_status_id  code
-----------------  --------
3                  APPROVED
```

16. Auditing and Action History

16.1 What the System Records

The project design foresees an audit table, *audit.audit_log*, fed by database triggers (ADR-009). **In the current version that table exists but nothing writes to it**: the changelogs reviewed do not create audit triggers and the services do not set the session context (action ACO-04 of the corrective, preventive, and improvement actions document). Until that function is built, the traces available to the administrator are those of Table 15.

Table 15

Traces Available in the Current Version

Source	What it contains	Typical use
security.user_session	Logins: user, start, expiry, revocation, IP address, and agent.	Detect unusual logins.
security.app_user.last_login	Last login of each account.	Identify unused accounts.
security.login_lockout	Failed attempts of each account and until when it is locked.	Detect attempts to guess passwords.
security.app_user (terms_accepted_at, data_policy_accepted_at)	Date each person accepted the legal documents.	Handle requests about consent.
payment.payment (approved_by, processed_at, rejection_reason)	Who approved a payment, when, and why it was rejected.	Review the approvals.
payment.payment_receipt (uploaded_by, uploaded_at)	Who uploaded each receipt and when.	Review the receipts.
payment.loyalty_transaction	Each point movement (earned and reversed) with its resulting balance.	Handle point claims.
booking.schedule_history	Changes of the hours, exceptions, and bays, with their date and author.	Know who changed the availability.
updated_at and row_version columns	Date and number of changes of each row (maintained by triggers).	Know when a record changed.
Container logs	Startup, errors, and requests with the correlation identifier.	Diagnose incidents.

Note. Prepared by the authors from the changelogs of the services. Logs must never contain passwords, tokens, or receipt content (Kent & Souppaya, 2006).

16.2 Audit Queries

Latest logins:

```
SELECT TOP (100) u.username, s.started_at, s.revoked_at, s.ip_address
FROM security.user_session s
JOIN security.app_user u ON u.user_id = s.user_id
ORDER BY s.started_at DESC;
```

Payments approved or rejected by each administrator:

```
SELECT p.approved_by, ps.code AS status, COUNT(*) AS payments, MAX(p.processed_at) AS
last_change
FROM payment.payment p
JOIN payment.payment_status ps ON ps.payment_status_id = p.payment_status_id
WHERE ps.code IN ('APPROVED', 'REJECTED', 'REFUNDED')
GROUP BY p.approved_by, ps.code;
```

Accounts without logins in the last 90 days:

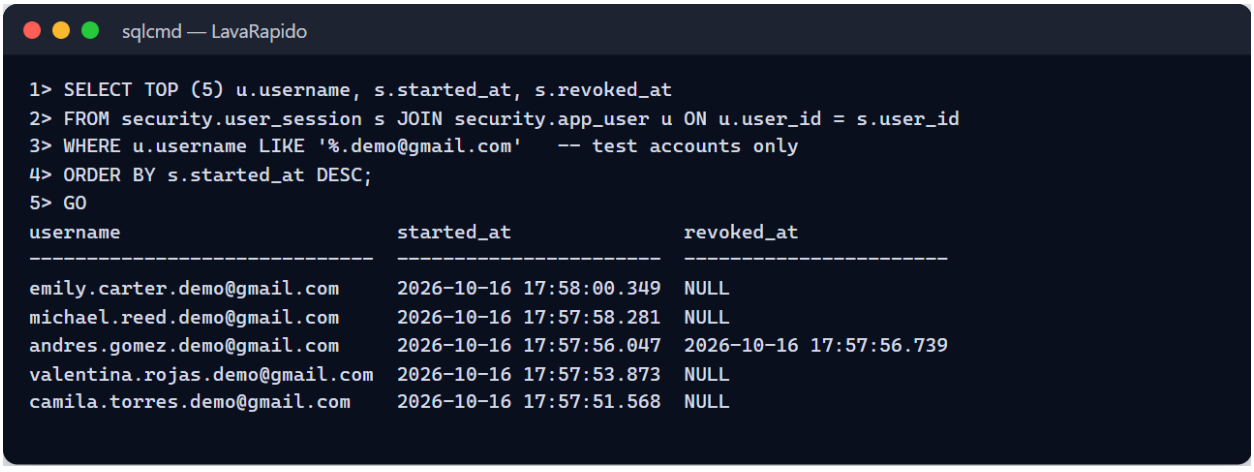
```
SELECT username, last_login, is_active
FROM security.app_user
WHERE last_login IS NULL OR last_login < DATEADD(day, -90, SYSUTCDATETIME());
```

16.3 Periodic Review and Retention

- Review weekly the new administrator accounts, the deactivated accounts, the payment accounts, and the approved payments.
- Investigate immediately any new account with the ADMIN role or any change of QR codes or payment accounts.
- The documentation does not define a retention policy. Recommendation: keep the session records for at least 12 months and archive the older ones in the monthly backups.
- When the audit triggers are built, do not modify or delete rows of *audit.audit_log*, because they would lose their evidentiary value.

Figure 15

Session History Query



17. Security Recommendations

The project's security policy is based on defense in depth, least privilege, secure defaults, security by design, and zero trust. The following recommendations are aligned with the NIST controls (Joint Task Force, 2020) and with the OWASP Top 10 (OWASP Foundation, 2021).

17.1 Accounts and Passwords

- Do not share the administrator password and use individual accounts.
- Use long and unique passwords stored in a password manager. The temporary lockout slows down repeated attempts, but it does not replace a strong password.
- Change any temporary password immediately.
- Deactivate the accounts of people who leave the process on the same day.
- Review the list of administrators quarterly: it must be as short as possible.
- Log out when finished and do not log in from shared machines.

17.2 Personal Data

The system processes personal data (ID number, names, phone, email, vehicles, and payments) and must comply with Statutory Law 1581 of 2012 (Congreso de la República de Colombia, 2012). Registration requires accepting the Terms and Conditions and the Personal Data Processing Policy; those documents are samples prepared for a training project and must be reviewed by a lawyer before real commercial use. When a person registers, the server stores the date and time each document was accepted (*security.app_user*, columns *terms_accepted_at* and *data_policy_accepted_at*), which serves as proof of consent. The administrator must consult only the data needed for the function, must not copy them to personal media, and must handle the requests of access or correction of the data subjects. No card data are collected. Backups and exports inherit the obligation of protection.

17.3 Secrets and Configuration

- The *.env* file is not versioned and has restricted permissions; the repository only contains *.env.example*.

- The JWT secret (minimum 32 bytes), the *sa* password, the RabbitMQ password, and *INTERNAL_API_KEY* must be changed before any shared deployment and immediately if a compromise is suspected. Changing the JWT secret invalidates all the tokens issued and forces everyone to log in again.
- In the current local environment the services connect with the *sa* account. Before any shared deployment, create a login per service with rights only on its own schemas (pending improvement).
- The demonstration accounts of the *dev* profile must never reach a shared deployment.

17.4 Network and Exposure

- Only the gateway (port 8080) and the web application should be exposed outside the machine; SQL Server, RabbitMQ, Mailpit, and the ports 3001 to 3006 must not be accessible from outside.
- Outside the local environment, use HTTPS with TLS 1.2 or higher. On the public server, Caddy also adds security headers and a content security policy (CSP) since October 20, 2026, and Docker checks the health of each container every 30 seconds (*docker compose ps* shows *healthy*).
- The gateway does not apply a request rate limit. Account lockout stops someone trying to guess passwords, but on a server exposed to the internet a rate limit should also be added in the proxy (Caddy) or in the gateway.

17.5 Accepted Risks the Administrator Must Know

Table 16

Risks and Administrator Measures

Risk	Recommended measure
The token of a closed session still works for up to 30 seconds (or until it expires, if security-service does not answer).	Deactivate the account, which closes all its sessions, and, if serious, rotate the JWT secret.
HS256 signature with a secret shared among services.	Protect the .env file and rotate the secret periodically.
The sign-in request limit lives in the gateway's memory: it resets with the gateway and counts per IP address.	Watch the gateway logs ("Demasiadas peticiones… desde X"): if X is an internal IP (172.x), all users share the limit and the team must be told.
Informative permission matrix (ADR-015), read-only since October 24, 2026.	Do not use the matrix as access control; real access depends on the role.
Without an Outbox, an event can be lost between the commit and its publication (since October 24, 2026 failed emails and push are retried up to 5 times and the operations queue has a dead-letter queue).	Review missing notifications and the dead-letter queues (*.dlq*).
Audit trail not populated.	Use the traces of section 16 and request the audit triggers.
Shared SQL Server instance for all the services.	Back up frequently and limit who accesses the instance.
Manual payment verification.	Always confirm against the business's bank statement.

Note. Prepared by the authors from ADR-004, ADR-006, ADR-008, and the technical backlog of the project.

17.6 Preventive Maintenance

Preventive maintenance reduces the probability of incidents and must be scheduled in the calendar of the IT administrator (Table 17). The frequencies are a proposal of this manual.

Table 17

Preventive Maintenance Plan

Frequency	Task	How to verify it
Daily	Confirm that the backup was generated and verified.	The file of the day and the backup log (on the public server, *tail -5 ~/lavarapido/backups/backup.log*).
Daily	Review the containers and the service errors.	docker compose ps and docker compose logs --since 24h.
Daily	Review payments pending review and bookings without an operator.	Control panel.
Weekly	Review the dead-letter queues of RabbitMQ.	Queues *notification-service.events.dlq* and *customer-service.events.dlq* at zero.
Weekly	Review disk space, the SQL Server volume, and the logs.	Usage below 80%.
Weekly	Review duplicate transaction references and new administrators.	Queries of sections 13.1 and 16.2.
Monthly	Test the restoration of a backup in a test environment.	Verification of section 15.3 (on the public server, *verify-backup.sh* does it every day).
Monthly	Check the integrity of the database.	DBCC CHECKDB without errors.
Monthly	Review updates of base images and security patches.	Versions of SQL Server, RabbitMQ, and Mailpit.
Quarterly	Review accounts and roles.	Users list and last login.
Quarterly	Review vulnerable dependencies.	./mvnw versions:display-dependency-updates, dotnet list package --vulnerable, and npm audit.
Quarterly	Rotate secrets (JWT, sa, RabbitMQ, internal key).	Login tests afterwards.
Yearly	Load the holidays of the following year; review this manual.	Exceptions loaded; version control.

```
# Quick health checks
docker compose ps
docker stats --no-stream
docker system df
docker compose exec sqlserver /opt/mssql-tools18/bin/sqlcmd -S localhost -U sa -P
"$DB_PASSWORD" -C \
  -Q "DBCC CHECKDB ([LavaRapido]) WITH NO_INFOMSGS"
```

17.7 Incident Resolution

An incident is handled with a fixed method: detect, contain, diagnose, fix, verify, and document. The first step of the diagnosis is to consult the log of the affected service, which includes the time, the level, the service name, and the correlation identifier. The root causes and the actions that prevent an incident from recurring are recorded in the corrective, preventive, and improvement actions document.

```
docker compose ps
docker compose logs --tail 100 <service>
docker compose logs --since 30m booking-service | grep -i error
```

Table 18

Frequent Administrator Incidents

Incident	Probable cause	Resolution
A user cannot log in	Forgotten password or deactivated account.	Check the status in Management > Users; direct the person to password recovery.
Everyone receives 401	Expired token or a JWT secret different among services.	Log in again; verify that all the services read the same JWT_SECRET.
Bookings cannot be created (503 CUSTOMER_SERVICE_UNAVAILABLE)	customer-service down or misconfigured.	Restart the service; review CUSTOMER_SERVICE_URL.
Operators cannot start services (503 BOOKING_SERVICE_UNAVAILABLE)	booking-service down.	Restart booking-service.
Bookings without an operator	No operator was free when the booking was confirmed (no shift, absent, or busy).	Assign by hand (section 12.4) and review the shifts and absences of the operators.
Bookings in To close	The operator served the vehicle but did not press Start or Finish, or the customer did not come.	Ask the operator and close with Attended or No-show (section 12.3); remind the team to record every service.
Payments fail through the gateway in Docker	The payment-service container is not running or payment-migrate failed.	Check *docker compose ps* and the log of payment-service (Installation Manual, section 17).
A payment cannot be approved	There is already an approved payment for the booking.	Review the payments of the booking and reject the duplicate.

Incident	Probable cause	Resolution
Payment approved without the money	Fake or poorly verified receipt.	Review who approved it (approved_by); contact the customer; refund it from Payments (section 12.6).
Notifications do not arrive	MESSAGING_ENABLED set to false, RabbitMQ down, or messages in the dead-letter queue.	Enable messaging, start RabbitMQ, and review the queues.
A customer does not receive coupon or reminder emails	The customer turned off the corresponding switch in Settings.	Check the switches of the customer (*security.user_preference*); the inbox still receives the notices.
Points were not credited after approving a payment	The services of the booking have 0 points, or payment-service could not read the booking.	Check the points of the services and BOOKING_SERVICE_URL.
The recovery code does not arrive	MAIL_ENABLED set to false or wrong SMTP settings.	Review MAIL_* and, locally, Mailpit (http://localhost:8025).
Times shifted in the bookings	Wrong time zone; the system stores UTC.	Review BOOKING_ZONE.
Disk full	Logs, backups, or data growth.	Free space safely and move the backups; never delete SQL Server data files.
The database does not respond	Container stopped, insufficient memory, or damaged file.	Review the SQL Server log and the memory assigned to Docker; if there is damage, restore (section 15).
Suspected compromised account	Unusual logins or unrecognized changes.	Deactivate the account, review the sessions, and rotate secrets if serious.

Note. Installation problems are detailed in the Installation Manual, section 17.

17.8 Severity Levels and Escalation

Table 19

Recommended Incident Severity

Severity	Example	Target response
Critical	System down, data loss, or compromised administrator account.	Immediate; notify the project leader.
High	Services cannot be booked or paid.	Within the same working day.
Medium	Notifications or emails that do not arrive.	Within two business days.
Low	Incorrect text or format.	Next delivery.

Note. Recommendation of this manual; the times must be approved by the team.

Every incident must be recorded with the date, who detected it, the description, the severity, the cause, the actions, the result, and the measures to prevent its recurrence (Annex C).

18. Glossary

Table 20

Glossary of Administration Terms

Term	Definition
Administrator	ADMIN role: runs the business and manages accounts, payments, and configuration.
Assignment	Link between an operator and a booking; created by the system when the booking is confirmed or by the administrator by hand.
Audit trail	Record of data changes with their author and date.
Bay	Physical washing spot; the number of active bays defines the capacity.
Coupon	Percentage discount that the customer unlocks with points and redeems when paying.
BCrypt	Algorithm with which passwords are stored as irreversible hashes.
Backup	Copy of the database that makes it possible to recover it.
Dead-letter queue (DLQ)	Queue where the messages that failed after retries are kept.
Deactivate	Prevent an account from logging in while keeping its history.
Exception (schedule)	Day that does not follow the regular schedule: holiday or special hours.
JWT	Signed token that identifies the user and the roles; lasts one hour.
Least privilege	Principle of giving each account only the permissions it needs.

Term	Definition
Loyalty points	Points that each service adds when its payment is approved; they are reversed if the payment is refunded.
Manual payment	Payment recorded by the administrator for money received at the business.
Refund	Return of the money of an approved payment, which reverses the points of the booking.
RPO	Maximum acceptable data loss, measured in time.
RTO	Maximum acceptable time to recover the service.
Severity	Level of seriousness of an incident.
To close	Home screen card with the bookings with an operator that ended without being recorded; the administrator closes them with Attended or No-show.

Note. Prepared by the authors from the project documentation.

References

Congreso de la República de Colombia. (2012). *Ley Estatutaria 1581 de 2012, por la cual se dictan disposiciones generales para la protección de datos personales* [Statutory Law 1581 of 2012, which issues general provisions for the protection of personal data]. http://www.secretariasenado.gov.co/senado/basedoc/ley_1581_2012.html

Joint Task Force. (2020). *Security and privacy controls for information systems and organizations* (NIST Special Publication 800-53, Rev. 5). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-53r5

Kent, K., & Souppaya, M. (2006). *Guide to computer security log management* (NIST Special Publication 800-92). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-92

Microsoft. (n.d.). *Back up and restore of SQL Server databases*. Microsoft Learn. Retrieved October 7, 2026, from https://learn.microsoft.com/sql/relational-databases/backup-restore/back-up-and-restore-of-sql-server-databases

OWASP Foundation. (2021). *OWASP Top 10:2021*. https://owasp.org/Top10/

Servicio Nacional de Aprendizaje. (2026). *Guía para elaborar manuales de software: Manual de usuario, manual técnico, manual de instalación y manual de administrador* [Guide for writing software manuals: User manual, technical manual, installation manual, and administrator manual] [Unpublished instructional material]. Technologist in Software Analysis and Development program.

Swanson, M., Bowen, P., Phillips, A. W., Gallup, D., & Lynes, D. (2010). *Contingency planning guide for federal information systems* (NIST Special Publication 800-34, Rev. 1). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-34r1

Vehicle Washing Development Team. (2026a). *Vehicle washing management system: Project documentation* (vehicle-w-docs) [Unpublished project documentation]. GitHub. https://github.com/code-sena/vehicle-w-docs

Vehicle Washing Development Team. (2026b). *Front-end-proyecto-web* (develop branch) [Computer software]. GitHub. https://github.com/BrayanCABRERA123/Front-end-proyecto-web

Vehicle Washing Development Team. (2026c). *lavarapido-payment-service* (develop branch) [Computer software]. GitHub. https://github.com/merari0322/lavarapido-payment-service

Vehicle Washing Development Team. (2026d). *lavarapido-security-service* (develop branch) [Computer software]. GitHub. https://github.com/BrayanCABRERA123/lavarapido-security-service

19. Annexes

Annex A. Source of the Screenshots

The figures in this manual were taken on October 16, 2026, on the version of the *develop* branch, with the whole system running in Docker and the web at *http://localhost:4200*. The terminal screenshots show the real output of the commands. Test accounts, bookings, payments, and payment methods were used, so no real passwords, bank accounts, QR codes, or personal data appear. If a screen changes, the screenshot must be taken again with the same file name in the *capturas* folder.

Annex B. Information to Confirm Before Delivery

Table 21

Information Pending Confirmation or Development

Topic	What is missing or contradictory	Section
Role permissions	The matrix is informative and read-only (ADR-015); enforcing it remains an improvement.	10
Audit trail	audit.audit_log is not populated.	16
Backup policy and RPO and RTO objectives	On the public server backups are automatic and checked every day (section 14.6); the RPO and RTO objectives and a copy outside the virtual machine still need approval.	14
Retention of traces	No policy defined.	16.3
One login per service	The services connect with the sa account.	17.3
Request rate limit	Since October 24, 2026 the gateway limits sign-in, sign-up, and recovery (60 per minute per IP); the rest of the API has no limit.	17.4
Payment queue	The web still requests the whole payment queue, with the images, every 45 seconds; with many payments it may be slow (ACO-33).	12.6

Note. Prepared by the authors from the verification of the source code and the technical backlog of the project.

Annex C. Incident Record Template

Table 22

Record of an Incident

Field	Content
Date and time of detection	
Detected by	
Description and symptoms	
Severity	Critical / High / Medium / Low
Affected services	
Correlation identifier or logs	
Cause	
Actions taken and person responsible	
Result and closing time	
Measures to prevent recurrence	

Annex D. Delivery Checklist

Table 23

Administrator Manual Checklist

Criterion	Met
Complete title page and version	Yes / No
Table of contents with updated pages	Yes / No
Objective and scope explained	Yes / No
The content matches the administration module of the final version	Yes / No
All figures replaced by real screenshots	Yes / No
Backup and restoration procedures tested on a real installation	Yes / No
No credentials, keys, or sensitive data	Yes / No
Items of Annex B reviewed	Yes / No
Exported to PDF with the name Manual_administrador_LavadoVehicular_3145556.pdf	Yes / No

Note. Adapted from the checklist of the guide for writing software manuals (SENA, 2026).